INTENDENCIA DE SAN JOSÉ

PORTAL VIAL

Ciberseguridad

Integrantes

Tomás Cabrera · Juan Robaina · Gabriela Romero · Verónica Romero · Juan Corrales

INTENDENCIA DE SAN JOSÉ

PORTAL VIAL

Análisis de ciberseguridad

Integrantes

Tomás Cabrera · Juan Robaina · Gabriela Romero · Verónica Romero · Juan Corrales

1. Alcance del análisis

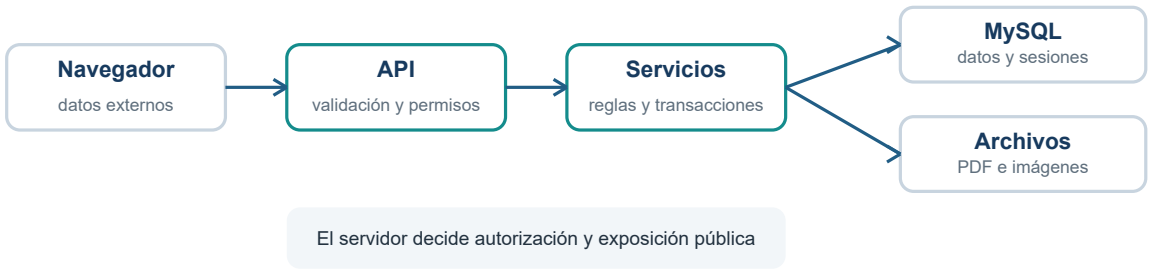
El análisis describe los activos, amenazas y controles de la versión PHP nativa y los relaciona con la evidencia disponible. Comprende el portal público, el panel IMSJ, la API, la base de datos, los archivos cargados y la infraestructura local Docker. La agenda y las reservas se evalúan como parte del alcance académico, aunque no formen parte de la entrega actual al cliente.

El análisis diferencia controles implementados, resultados registrados y límites de alcance. Las comprobaciones SAST, DAST, Nmap y Bash se documentan en sus informes específicos. La presencia de un control en el código no acredita por sí sola ausencia de vulnerabilidades; por eso cada resultado conserva su contexto y evidencia.

2. Activos y límites de confianza

Activo	Información o función que debe protegerse	Consecuencia de un incidente
Cuentas y contraseñas	Identidad, rol y acceso al panel y a reservas propias.	Suplantación y ejecución de operaciones no autorizadas.
Tokens de sesión	Acceso temporal a las operaciones de la cuenta.	Uso de una sesión robada hasta su vencimiento o revocación.
Noticias, materiales y FAQ	Integridad, aprobación, publicación y vigencia de la información.	Difusión de contenido falso, interno o desactualizado.
Consultas ciudadanas	Nombre, correo y mensaje.	Exposición de datos o uso de la bandeja para abuso y contenido malicioso.
Banco del simulador	Enunciados, gráficos, opciones y respuestas correctas.	Alteración educativa o exposición anticipada de la solución.
Reservas y franjas	Relación de ciudadano, horario y cupo.	Cancelación ajena, duplicación o exceso de capacidad.
Historial	Usuario, acción, elemento y fecha.	Pérdida de trazabilidad o atribución incorrecta de acciones.
Adjuntos y respaldos	PDF, imágenes, exportaciones y configuración de instalación.	Pérdida de información, descarga indebida o ejecución de archivos inseguros.

El navegador y sus datos se consideran entradas externas. Ocultar un botón no autoriza ni prohíbe una operación: la API debe comprobar la sesión y los permisos. La base y el almacenamiento se acceden desde el servidor; los archivos del backend fuera de `public` no deben publicarse como recursos estáticos.



3. Amenazas y efectos sobre el proyecto

Amenaza	Escenario relevante	Impacto técnico y sobre usuarios
Inyección SQL	Entradas manipuladas en acceso, filtros y operaciones de administración.	Lectura o modificación de cuentas, contenidos y datos de ciudadanos si una consulta concatena entradas sin control.
XSS almacenado o reflejado	Texto, enlaces o mensajes incorporados al DOM sin codificación contextual.	Ejecución en el navegador, redirección, alteración visual o robo del token accesible a JavaScript.
Fuerza bruta y robo de credenciales	Intentos automatizados, claves previsibles o engaño al personal.	Acceso a una cuenta y acciones atribuidas a su identidad.
Fallas de autorización	Invocar directamente una ruta administrativa o un identificador de otra cuenta.	Publicación sin permiso, lectura de información interna o cancelación de reservas ajenas.
Archivos inseguros	Carga de un archivo ejecutable, contenido distinto del tipo declarado o ruta manipulada.	Ejecución, exposición de archivos privados o consumo indebido de recursos.
Pérdida de integridad	Falla parcial entre SQL, historial y adjuntos, o solicitudes simultáneas por el último cupo.	Registros inconsistentes, archivos huérfanos o más reservas que capacidad.
Exposición de configuración	Publicación de `.env`, SQL, mensajes internos, logs o respaldos.	Filtración de claves y datos y acceso a servicios de la instalación.
Falta de recuperación	Pérdida de volumen o copia sin adjuntos, configuración o versión compatible.	Interrupción del servicio e imposibilidad de reconstruir su estado.

Mapa de riesgos

El mapa original se conserva y se interpreta sobre la implementación actual: backend en **PHP nativo, sin framework**, organizado por capas y con acceso a MySQL mediante PDO. La ubicación de los riesgos es una estimación cualitativa del equipo para priorizar revisiones; no sustituye una auditoría técnica ni una aceptación institucional del riesgo.

Código	Riesgo	Componente principal	Probabilidad	Impacto	Nivel	Justificación resumida
R1	Inyección SQL	Login, filtros y operaciones administrativas	Baja	Alto	Medio	El uso sistemático de PDO con consultas preparadas reduce la probabilidad, pero una regresión permitiría comprometer cuentas y datos.
R2	XSS almacenado	Noticias, materiales, FAQ y consultas	Media	Medio	Medio	Existen salidas seguras, aunque los usos de `innerHTML` y las URL construidas por el frontend requieren revisión contextual completa.
R3	Robo de credenciales o fuerza bruta	Acceso de personal y Directora	Alta	Alto	Alto	Bcrypt y el límite de intentos reducen ataques directos, pero no eliminan phishing, reutilización de claves ni robo del token accesible al navegador.
R4	Falla de control de acceso	API administrativa, contenidos y reservas	Media	Alto	Alto	La API verifica sesión, cuenta activa, rol y propiedad; un error en una ruta nueva o modificada tendría consecuencias amplias.

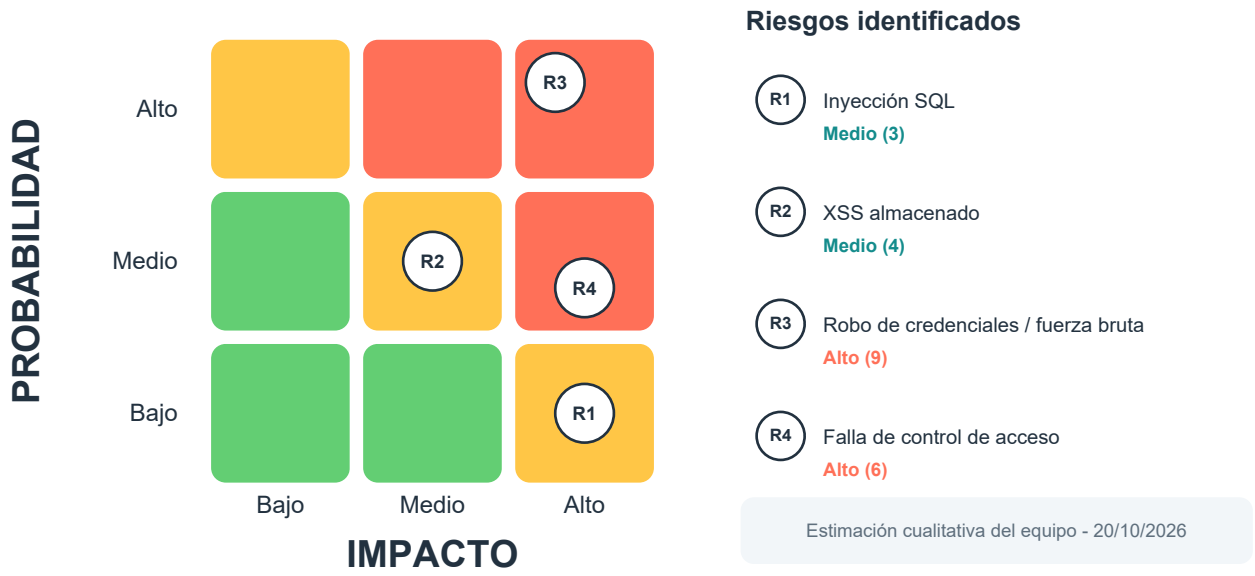


Figura 1. Mapa de riesgos del proyecto: probabilidad frente a impacto.

Criterio de escala del mapa. La probabilidad se valora como **Baja (1)** cuando el escenario exige condiciones excepcionales o los controles actuales reducen de forma clara su ocurrencia; **Media (2)** cuando el escenario es plausible y existe exposición o cobertura parcial; y **Alta (3)** cuando puede ocurrir con facilidad, depende también de factores humanos o los controles no bastan para prevenirlo. El impacto es **Bajo (1)** si el efecto es limitado, reversible y no compromete datos sensibles ni funciones críticas; **Medio (2)** si afecta temporalmente una función o un conjunto acotado de datos o usuarios; y **Alto (3)** si permite acceso privilegiado, exposición o alteración relevante de datos, publicación maliciosa o indisponibilidad significativa. El nivel se obtiene multiplicando probabilidad por impacto: **Bajo (1-2, verde)**, **Medio (3-4, amarillo)** y **Alto (6-9, rojo)**. La valoración fue realizada por el equipo del proyecto el 20/10/2026 y debe revisarse después de cada cambio relevante o nueva prueba de seguridad.

El mapa también conserva la relación con los componentes y efectos analizados originalmente:

Componente del sistema	Amenaza(s) asociada(s)	Impacto técnico	Impacto sobre usuarios
Login administrativo	Inyección SQL; robo de credenciales; fuerza bruta.	Omisión de autenticación, acceso a una cuenta y ejecución de acciones con permisos del personal.	Suplantación de identidad y atribución incorrecta de cambios en el historial.
Carga de contenidos	XSS almacenado; fallas de acceso; archivos inseguros.	Publicación o modificación no autorizada, almacenamiento de contenido malicioso y pérdida de integridad.	Información falsa, desactualizada o maliciosa desde un sitio identificado como oficial.
Consulta pública	XSS almacenado; exposición de contenido no publicado.	Ejecución en el navegador y visualización anticipada de contenido interno.	Redirecciones, contenido manipulado o acceso antes de su aprobación y vigencia.
Base de datos	Inyección SQL; acceso no autorizado.	Lectura, alteración o eliminación de cuentas, contenidos, consultas, reservas e historial.	Exposición de datos, pérdida de información pública o interrupción del servicio.

4. Controles presentes y límites

Área	Implementación disponible	Límite o evidencia adicional necesaria
Contraseñas	Hash bcrypt con costo 12 y `password_verify`; la salida del usuario omite el hash.	La política institucional de claves, recuperación y cuentas debe acordarse. El alta posterior de personal conserva una clave inicial fija.
Sesiones	Bearer opaco, secreto aleatorio de 32 bytes, hash SHA-256 y ocho horas de vigencia. Ingreso revoca sesiones previas; logout y desactivación revocan tokens.	`sessionStorage` es accesible a scripts del mismo origen; la prevención de XSS y HTTPS son necesarias en el entorno real.
Roles	Comprobación de cuenta activa y rol en cada operación protegida; Directora hereda acceso de personal y es la única que aprueba.	La asignación y revisión institucional de permisos no se deduce de las cuentas de demostración.
Intentos de acceso	Cinco intentos por minuto por IP y operación para login/registro, con contador y bloqueo de archivo compartido.	No es un limitador general de todas las rutas; varias instancias necesitan caché compartida.
SQL e integridad	PDO preparado, transacciones, claves foráneas y restricciones únicas. Reserva bloquea la franja antes de comprobar cupo.	La parametrización no sustituye los permisos y las reglas de negocio.
Entradas y errores	`Solicitud` valida JSON/multipart, tipos, tamaños, opciones, fechas, horas, cédulas y URL. Los errores internos no devuelven SQL o claves.	La validación del navegador es complementaria. Se debe revisar cada contexto de salida de HTML y URL.
Archivos	MIME/contenido, límites por recurso, nombres aleatorios y rutas restringidas fuera de `public`.	VIDEO usa URL externa; los proveedores y sus condiciones deben definirse para la operación institucional.
Publicación	Estados Borrador, Pendiente, Aprobado y Publicado; edición devuelve a borrador y noticias se filtran por vigencia.	Una aprobación técnica de contenido no es una aceptación del proyecto.
Auditoría	Operaciones administrativas guardan usuario, acción, fecha y elemento en la misma transacción de datos.	No conserva valores anterior/nuevo; cobertura total y retención están por acordar. La cancelación ciudadana elimina la reserva sin estado histórico.
Infraestructura	MySQL sin puerto del host, frontends montados en lectura y raíz Apache limitada a `public`.	La configuración local no incorpora dominio ni HTTPS de producción; falta evidencia final de hardening y recuperación.

5. Superficies específicas

Contenidos y consultas

Noticias, materiales y FAQ se administran con sesión y permisos. El portal solo debe consumir la representación pública. La bandeja de consultas contiene datos personales y su lectura requiere acceso de personal; el formulario público no expone su listado. La revisión de salida debe considerar los módulos que utilizan `innerHTML`, además de los que construyen nodos con `textContent`.

Simulacro

La consulta pública omite la respuesta correcta. La corrección obtiene la solución desde la base, sin aceptar del navegador una marca de respuesta verdadera. Las imágenes admitidas son JPG, PNG y WEBP de hasta 2048 KB. Debe comprobarse tanto la carga válida como el rechazo de contenido ejecutable y la descarga del recurso almacenado.

Agenda académica

La reserva se asocia a la cuenta del token. La transacción y el bloqueo impiden superar el cupo por solicitudes simultáneas, y la unicidad evita duplicación por ciudadano/franja. La ruta DELETE comprueba el propietario; personal recibe rechazo de rol y otra cuenta ciudadana no puede eliminar el registro. El borrado libera capacidad y no conserva un historial de cancelación.

Los listados solo muestran fechas vigentes; ese filtro de presentación no elimina los registros pasados ni define su conservación. La política de retención debe contemplar datos efectivamente guardados, no solo lo que la interfaz permite ver.

6. Evidencia final

La entrega reúne evidencia técnica de las tres etapas de Ciberseguridad:

- Análisis de amenazas, mapa de riesgos y controles aplicables.
- Semgrep con hallazgos y correcciones documentadas.
- OWASP ZAP y Nmap sobre el entorno local autorizado.
- Auditoría Bash de autenticación, permisos, entradas y archivos.
- Hardening de Apache/PHP y MySQL mediante Docker Compose.
- Registro de hallazgos y procedimiento de respuesta a incidentes.
- Términos y privacidad incluidos; los datos institucionales se completarán con información validada por la Intendencia.

7. Cierre

Las pruebas se realizaron sobre el entorno local autorizado y con datos de prueba. Los resultados describen el alcance evaluado y no afirman ausencia absoluta de vulnerabilidades. No se atacaron sistemas externos ni se utilizaron datos personales reales.

8. Referencias

- Requisitos, arquitectura, infraestructura y contrato de API.
- OWASP SQL Injection.
- OWASP XSS Prevention.
- OWASP Authentication y Authorization.
- OWASP Input Validation y Password Storage.
- OWASP Logging y File Upload.

INTENDENCIA DE SAN JOSÉ

PORTAL VIAL

Informe SAST

Integrantes

Tomás Cabrera · Juan Robaina · Gabriela Romero · Verónica Romero · Juan Corrales

Resumen ejecutivo

Semgrep informó 11 coincidencias y las marcó como bloqueantes para su política de salida. La cifra no equivale a 11 vulnerabilidades explotables. Ocho coincidencias corresponden a una misma debilidad de suministro en páginas HTML y tres requieren interpretar controles del backend.

Resultado del triage	Coincidencias	Lectura
Debilidad confirmada	8	Script de unpkg sin atributo integrity en ocho páginas públicas
Mitigada por el código	2	Ruta de caché basada en hash y borrado restringido a UPLOAD_ROOT
No explotable en el flujo revisado	1	Comando de verificación CLI con argumentos escapados y archivos de un directorio fijo

Decisión recomendada

Antes de publicar el portal, hospedar localmente Lucide o fijar la versión con Subresource Integrity y crossorigin. Después, repetir Semgrep y conservar el JSON de revalidación. Las tres alertas del backend no justifican por sí solas bloquear la entrega, pero conviene refactorizar el verificador de sintaxis para evitar la invocación mediante shell.

Prioridad de trabajo

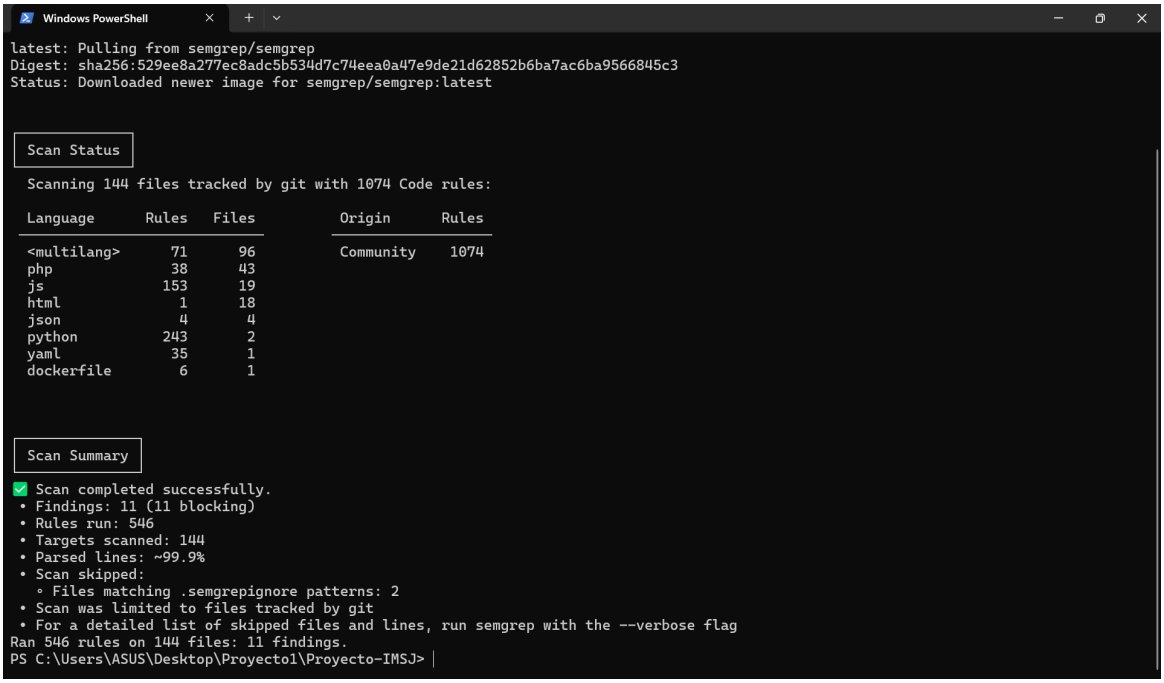
Orden	Acción	Criterio de cierre
1	Eliminar o verificar el script remoto en ocho HTML	Sin alertas missing-integrity y sin pérdida de iconos
2	Reemplazar passthru por una ejecución sin shell	El script verifica todos los PHP sin alerta exec-use
3	Documentar supresiones justificadas en Auth y Archivo	Excepción breve, localizada y asociada al control existente
4	Repetir el escaneo con salida fuera del repositorio	JSON sin error por autolectura y cobertura revisada

Alcance y método

El análisis se ejecutó con la imagen semgrep/semgrep y la configuración automática. La consola cargó 1.074 reglas comunitarias y aplicó 546 reglas compatibles a 144 archivos seguidos por Git. El reporte JSON identifica Semgrep OSS 1.180.0 y 11 resultados.

Lenguaje	Reglas mostradas	Archivos
Multilenguaje	71	96
PHP	38	43
JavaScript	153	19
HTML	1	18
JSON	4	4
Python	243	2
YAML	35	1
Dockerfile	6	1

Evidencia de ejecución



Captura 1. Resumen de la ejecución de Semgrep proporcionado con el análisis.

Cobertura y limitaciones

El resultado cubre el código que Semgrep alcanzó a analizar con las reglas aplicables. No sustituye pruebas dinámicas, revisión de configuración en ejecución, pruebas autenticadas ni análisis de dependencias. Un resultado sin alertas tampoco demostraría ausencia de vulnerabilidades.

Incidencia	Efecto	Tratamiento
sast-report.json produjo un error de sintaxis durante el escaneo	La redirección creó el archivo de salida dentro del volumen antes de que Semgrep terminara	Generar la salida fuera del repositorio o excluir ese nombre
Dockerfile tuvo análisis parcial entre las líneas 5 y 18	Parte de ese archivo pudo no recibir todas las reglas previstas	Revisar sintaxis y reanalizar el Dockerfile
Timeout de punto fijo en backend/public/index.php	Una regla de análisis de flujo no completó su evaluación	Repetir con mayor capacidad o una regla dirigida
Dos archivos ignorados y alcance limitado a Git	Archivos ignorados o no seguidos quedaron fuera	Revisar .semgrepignore y confirmar que el alcance sea intencional

Conclusión de cobertura. Los 11 resultados pueden analizarse, pero el informe no debe presentarse como una certificación integral del proyecto. La revalidación debe cerrar las incidencias de cobertura y demostrar la corrección del hallazgo confirmado.

Triage de hallazgos

ID	Regla y ubicación	Semgrep	Triage	Prioridad
SAST 01	missing-integrity en 8 páginas públicas	WARNING	Confirmado	Media
SAST 02	exec-use en backend/scripts/verificar.php:22	ERROR	No explotable en el flujo	Baja
SAST 03	unlink-use en backend/models/Archivo.php:80	WARNING	Mitigado	Baja
SAST 04	tainted-filename en backend/core/Auth.php:62	WARNING	Falso positivo	Informativa

Criterio aplicado

La severidad de Semgrep se conserva como dato de la herramienta. La prioridad del informe considera si la entrada es controlable por un atacante, qué validaciones se ejecutan antes del punto sensible y si el flujo está expuesto por HTTP o limitado a una utilidad local.

Distribución del resultado bruto

Severidad	Cantidad	Reglas
ERROR	1	php.lang.security.exec-use.exec-use
WARNING	10	tainted-filename, unlink-use y missing-integrity

SAST 01
Dependencia externa sin verificación de integridad

CONFIRMADO

Severidad de Semgrep: WARNING

Ocho páginas cargan la versión 0.468.0 de Lucide desde unpkg. La versión está fijada, pero las etiquetas script no incluyen el atributo integrity. Si el contenido remoto o su cadena de distribución fuese alterado, el navegador ejecutaría el JavaScript modificado con los permisos de la página.

Evidencia

Archivo	Línea	Recurso
frontend-publico/agenda.html	21	unpkg.com/lucide@0.468.0/dist/umd/lucide.min.js
frontend-publico/consulta.html	21	unpkg.com/lucide@0.468.0/dist/umd/lucide.min.js
frontend-publico/estudio.html	21	unpkg.com/lucide@0.468.0/dist/umd/lucide.min.js
frontend-publico/index.html	151	unpkg.com/lucide@0.468.0/dist/umd/lucide.min.js
frontend-publico/noticias.html	86	unpkg.com/lucide@0.468.0/dist/umd/lucide.min.js
frontend-publico/preguntas.html	21	unpkg.com/lucide@0.468.0/dist/umd/lucide.min.js
frontend-publico/prueba.html	32	unpkg.com/lucide@0.468.0/dist/umd/lucide.min.js
frontend-publico/renovagenda.html	25	unpkg.com/lucide@0.468.0/dist/umd/lucide.min.js

Clasificación

CWE-353 Missing Support for Integrity Check. OWASP A08 Software and Data Integrity Failures.

Corrección recomendada

Opción	Implementación	Observación
Preferida	Hospedar lucide.min.js dentro del proyecto y servirlo desde el mismo origen	Reduce la dependencia operativa del CDN
Alternativa	Agregar integrity con el hash del archivo exacto y crossorigin=anonymous	Actualizar el hash cuando cambie la versión

Validación

Abrir las ocho páginas, verificar que los iconos se rendericen y repetir Semgrep. El cierre exige cero coincidencias de missing-integrity o una excepción documentada si se adopta otra arquitectura.

Hallazgos del backend

SAST 02
Ejecución de un comando construido dinámicamente

NO EXPLOTABLE

Severidad de Semgrep: ERROR

La línea 22 usa passthru para ejecutar el verificador de sintaxis de PHP. Semgrep trata cualquier comando no constante como posible inyección. En este flujo, PHP_BINARY es una constante del intérprete, los archivos se enumeran bajo backend y tanto el binario como la ruta pasan por escapeshellarg. Además, el script termina si no se ejecuta por CLI. No se identificó una entrada HTTP o un argumento del usuario que alcance el comando.

```
passthru(escapeshellarg(PHP_BINARY) . ' -l ' . escapeshellarg($file->getPathname()), $status);
```

Riesgo residual y mejora

El uso de una cadena de shell mantiene una superficie innecesaria y dificulta el análisis automático. Reemplazarlo por proc_open con una lista de argumentos, o por una API de procesos que no invoque shell, conserva la función y elimina el patrón reportado.

SAST 03
Eliminación de archivo a partir de una ruta variable

MITIGADO

Severidad de Semgrep: WARNING

Archivo::delete recibe una ruta variable, pero rechaza URLs, resuelve la ruta real desde UPLOAD_ROOT, exige que permanezca dentro de ese directorio y confirma que el destino sea un archivo antes de llamar a unlink. Estos controles bloquean el recorrido de directorios que describe CWE-22 en el flujo revisado.

```
!unlink($resolved)
```

Riesgo residual y mejora

Conservar las comprobaciones juntas y agregar pruebas automatizadas con rutas ../, rutas absolutas, URLs y enlaces simbólicos. Si la alerta se suprime, hacerlo en la línea exacta e indicar que realpath y la comparación con UPLOAD_ROOT son el control compensatorio.

SAST 04
Nombre de archivo derivado de datos de la solicitud

FALSO POSITIVO

Severidad de Semgrep: WARNING

El nombre de la caché combina la operación y la IP, pero antes de crear el archivo aplica SHA-256. El resultado es una cadena hexadecimal de longitud fija. CACHE_ROOT proviene de la configuración del servidor y el código no realiza una solicitud de red, por lo que la clasificación SSRF de la regla no coincide con el comportamiento observado.

```
$file = fopen(CACHE_ROOT . '/' . $key . '.json', 'c+');
```

Tratamiento

Mantener el hash y la raíz de caché fija. Documentar una supresión localizada con la justificación anterior y una prueba que confirme que el nombre final solo contiene 64 caracteres hexadecimales seguidos de .json.

Plan de corrección y revalidación

Paso	Responsable sugerido	Trabajo	Evidencia
1	Frontend	Autohospedar Lucide o configurar SRI en ocho HTML	Diff y prueba visual
2	Backend	Eliminar la cadena de shell en verificar.php	Salida del verificador
3	Backend y QA	Agregar pruebas de rutas y nombre de caché	Pruebas automatizadas
4	QA	Repetir Semgrep y revisar errores de cobertura	Nuevo JSON y captura
5	Revisión interna	Comparar resultados y aprobar excepciones	Acta o registro de cierre

Comando de revalidación

```
$tempReport = Join-Path $env:TEMP 'imsj-sast-report.json'
docker run --rm -v "${PWD}:/src" semgrep/semgrep semgrep scan --config auto --exclude sast-report.json --json >
$tempReport
Copy-Item -LiteralPath $tempReport -Destination .\sast-report.json -Force
```

El archivo temporal evita que Semgrep intente analizar su propia salida mientras se está escribiendo. La exclusión mantiene el comportamiento correcto si ya existe una copia del JSON en el repositorio.

Criterios de cierre

Control	Condición de aceptación
Integridad de recursos	Cero alertas missing-integrity y páginas funcionales
Backend	Sin alerta exec-use o con excepción técnicamente justificada
Cobertura	Sin autolectura del JSON y con Dockerfile e index.php revisados
Trazabilidad	JSON, captura, commit y decisión de triage conservados

Conclusión

El hallazgo accionable del escaneo es la falta de verificación de integridad del script remoto en ocho páginas públicas. Las alertas de backend no muestran una vía de explotación en el código revisado, aunque una mejora en verificar.php facilitará el cierre automático. El informe debe actualizarse después de aplicar las correcciones y repetir el análisis.

Revalidación posterior a correcciones

Semgrep OSS se ejecutó nuevamente el 21/10/2026 sobre el árbol de trabajo derivado del commit **5f15b3b**. La ejecución terminó correctamente y produjo un JSON independiente para comparar los resultados antes y después de las correcciones.

11	6	0	546
coincidencias iniciales	coincidencias posteriores	missing-integrity restantes	reglas ejecutadas

Comparación y decisión

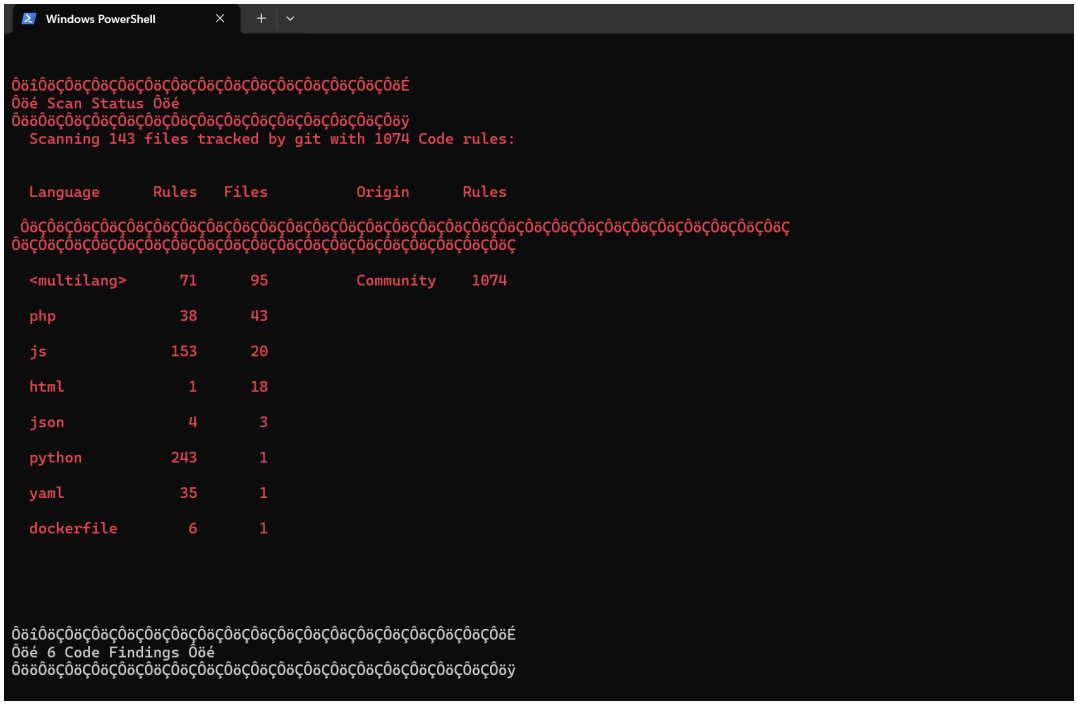
Control	Antes	Después	Decisión
Integridad de recursos	8 alertas por Lucide remoto sin integrity.	0 alertas; los iconos se sirven desde un archivo local.	Cerrado.
Ejecución de procesos	passthru con comando construido como texto.	proc_open recibe una lista de argumentos y no invoca un shell.	Mitigado; Semgrep conserva 1 alerta por el uso del sink.
Ruta de caché	1 alerta tainted-filename.	Permanece la coincidencia; la clave continúa reducida a SHA-256 y raíz fija.	Falso positivo documentado.
Borrado de archivos	1 alerta unlink-use.	Permanece la coincidencia; realpath y UPLOAD_ROOT restringen el destino.	Mitigado; mantener pruebas de rutas.
Formularios de acceso	No se informaba CSRF porque no declaraban POST.	3 alertas de una regla para plantillas Django.	No aplicable: HTML estático, API PHP y autenticación Bearer sin cookies.

Conclusión SAST

La debilidad confirmada de cadena de suministro quedó corregida. Las seis coincidencias posteriores no representan seis vulnerabilidades explotables: tres son la regla Django aplicada fuera de contexto, dos conservan controles compensatorios ya revisados y una corresponde a una utilidad CLI que ahora ejecuta PHP sin construir una línea de shell.

Evidencia y límites de cobertura

Captura 2. Resumen de la segunda ejecución de Semgrep proporcionada por el equipo.



Trazabilidad

Artefacto	SHA-256
informes-sast-post/semgrep-post.json	1A11FF607656121E675DE1EE7D31A0BCAA7BD6CD18B2A402ED27A87478FDDE59
informes-sast-post/semgrep-post-terminal.txt	F48B522056EB3C56A94DE8D0000C3432D4EDBC84792F7F5BAF20073CCFE66E63

Limitaciones

La ejecución registró 1 advertencia de análisis parcial sobre el Dockerfile. Además, Semgrep indicó que limitó el alcance a archivos seguidos por Git: el nuevo archivo local de iconos todavía no estaba versionado y el ajuste final del nombre de la configuración Apache ocurrió después de esta ejecución. El cierre formal debe identificar el commit final y, si se exige cobertura exacta de todo el corte, repetir Semgrep una vez versionados esos cambios.

INTENDENCIA DE SAN JOSÉ

PORTAL VIAL

Hardening de contenedores

Integrantes

Tomás Cabrera · Juan Robaina · Gabriela Romero · Verónica Romero · Juan Corrales

1. Resumen ejecutivo

Se endurecieron los dos servicios Docker del proyecto IMSJ sin alterar su funcionalidad observable. La aplicación se ejecuta íntegramente como www-data; MySQL lo hace como mysql. Ambos contenedores impiden la elevación de privilegios, descartan capacidades Linux y utilizan una raíz de solo lectura. Apache conserva únicamente CAP_NET_BIND_SERVICE para escuchar en el puerto interno 80; MySQL no conserva capacidades adicionales.

Conclusión

Los controles quedaron incorporados al compose.yaml del proyecto. Los dos healthchecks finalizaron en estado healthy y la auditoría de regresión no registró fallos.

2. Objetivo y alcance

El objetivo fue reducir el impacto de una eventual explotación dentro de los contenedores y comprobar que las restricciones no impiden el arranque, la persistencia, los healthchecks ni los controles de seguridad de la API. Las pruebas se realizaron en un entorno Docker local autorizado con datos de prueba. El despliegue final se define para Ubuntu Server 24.04 LTS. No se atacaron sistemas externos.

3. Metodología

Paso	Actividad	Criterio de aceptación
1	Línea de base y healthchecks	app y db saludables; MySQL sin puerto publicado
2	Aplicación gradual de controles	Recrear un servicio por vez y conservar disponibilidad
3	Inspección de runtime	Usuario, capacidades, no-new-privileges y ReadonlyRootfs visibles
4	Regresión de API	Cero pruebas fallidas y salida 0
5	Arranque habitual	docker compose up -d conserva los controles

4. Matriz de controles aplicados

Control	Aplicación	MySQL	Resultado
Usuario no privilegiado	www-data	mysql (UID 999)	Cumple
no-new-privileges	Activo	Activo	Cumple
Capacidades Linux	DROP ALL; agrega NET_BIND_SERVICE	DROP ALL; no agrega	Cumple
Raíz de solo lectura	Activa	Activa	Cumple
Directorios temporales	/tmp, /run/apache2, /var/lock/apache2	/tmp, /var/run/mysqld	Cumple
Datos persistentes	uploads y cache en volúmenes	db_data en volumen	Cumple
Exposición de red	APP_BIND:APP_PORT -> 80	Sin publicación al host	Cumple

Configuración efectiva resumida

```
services:
  app:
    user: www-data
    security_opt: [no-new-privileges:true]
    read_only: true
    cap_drop: [ALL]
    cap_add: [NET_BIND_SERVICE]
    tmpfs: [/tmp, /run/apache2, /var/lock/apache2]

  db:
    user: mysql
    security_opt: [no-new-privileges:true]
    read_only: true
    cap_drop: [ALL]
    tmpfs: [/tmp, /var/run/mysqld]
```

Evidencia 1

Bloqueo de elevación de privilegios

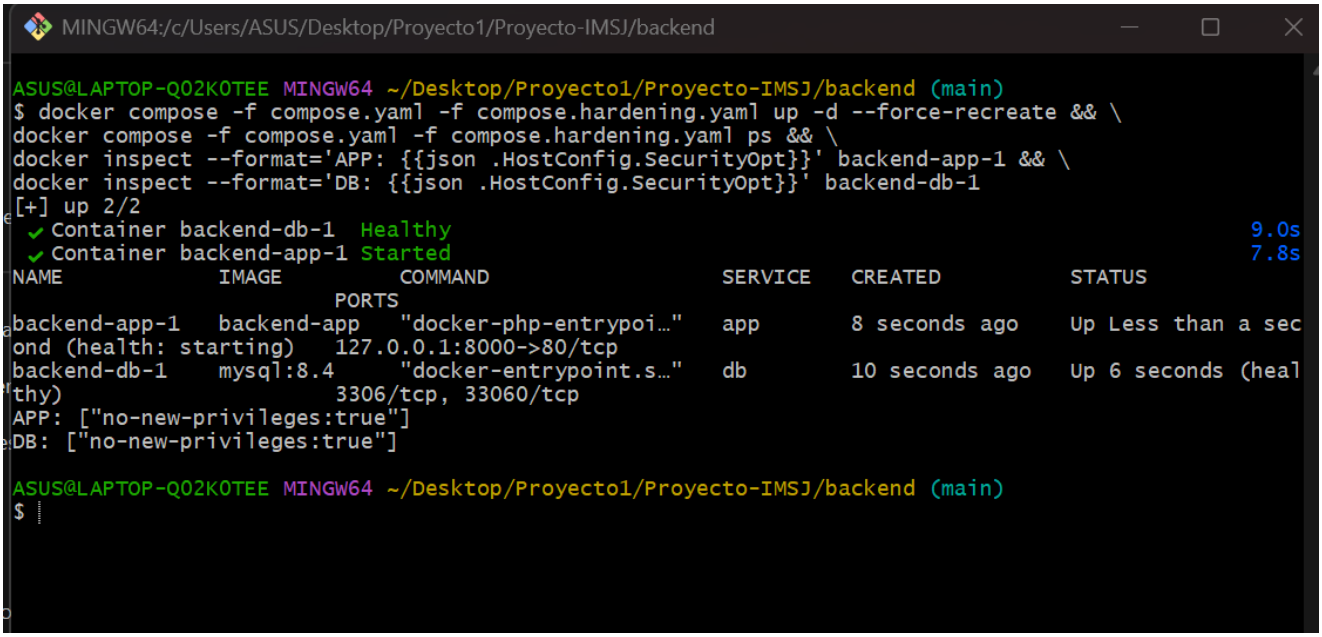


Figura 1. Primera aplicación del control security_opt en ambos servicios.

- La inspección devuelve no-new-privileges:true para app y db.
- Ambos servicios completan el arranque; la aplicación pasa a healthy segundos después, confirmado en la verificación siguiente.
- El control impide que procesos dentro del contenedor adquieran privilegios adicionales mediante binarios setuid o mecanismos equivalentes.

Evidencia 2

Usuario no privilegiado y capacidades mínimas en Apache

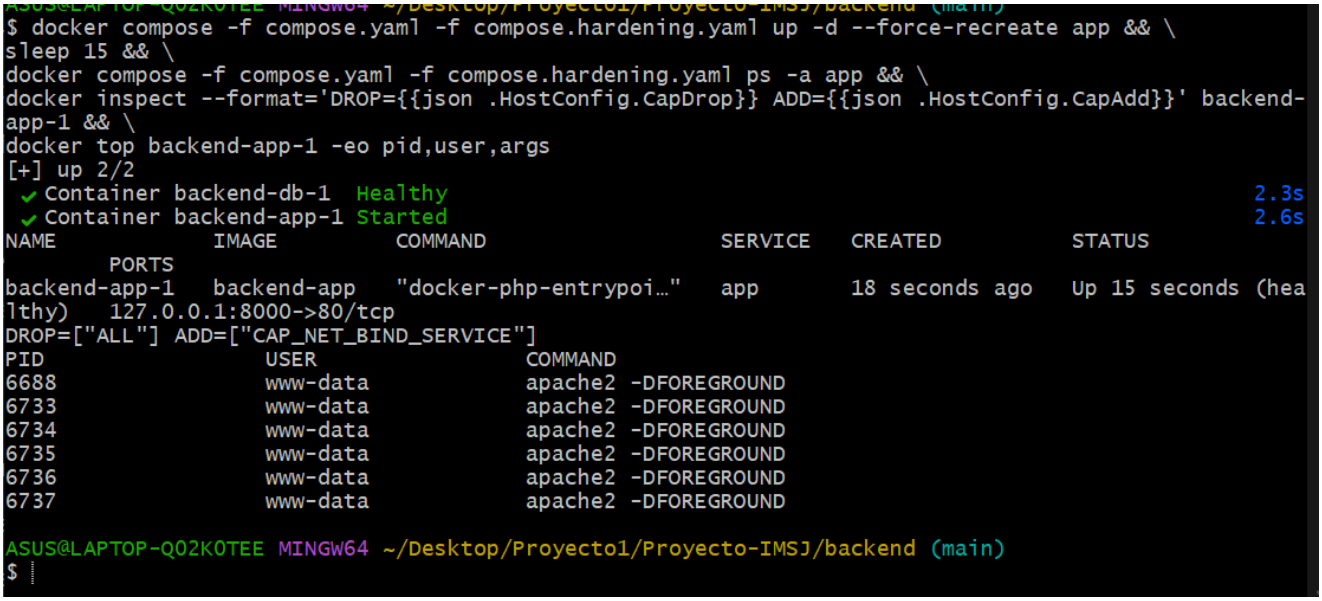


Figura 2. Estado de app después de reducir capacidades y ejecutar Apache íntegramente como www-data.

- El servicio app permanece healthy con todas las capacidades descartadas.
- Se agrega únicamente CAP_NET_BIND_SERVICE para conservar el puerto interno 80.
- Todos los procesos Apache observados se ejecutan como www-data; no queda un proceso maestro root.

Evidencia 3

Raíz de solo lectura y capacidades eliminadas en MySQL



Figura 3. Configuración efectiva del contenedor de base de datos.

- app y db aparecen healthy durante la misma verificación.
- MySQL informa READ_ONLY=true, DROP=[ALL] y ADD=null.
- El proceso mysqld utiliza UID 999, correspondiente al usuario mysql de la imagen.
- La base conserva escritura únicamente en su volumen de datos y en tmpfs temporales.

Evidencia 4

Revalidación funcional y de seguridad

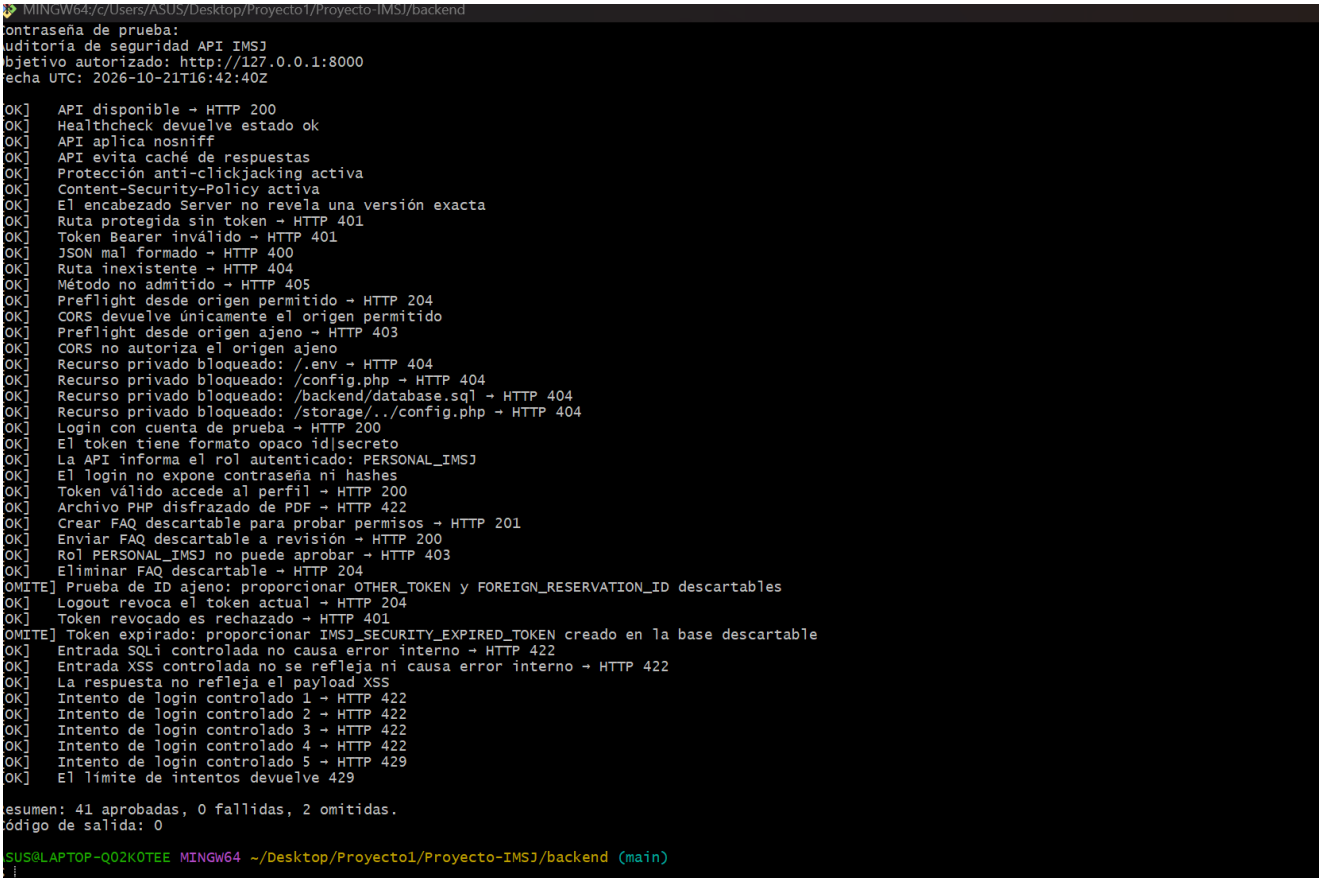


Figura 4. Auditoría Bash ejecutada nuevamente después del hardening.

- Resultado: 41 aprobadas, 0 fallidas y 2 omitidas; código de salida 0.
- La prueba incluye healthcheck, cabeceras, CORS, autenticación, rol PERSONAL_IMSJ, carga maliciosa, operaciones descartables, SQLi/XSS controladas y rate limiting.
- Las dos omisiones son token expirado e ID ajeno, ya acreditadas en la ejecución estricta anterior de 43 aprobadas, 0 fallidas y 0 omitidas.

Persistencia del hardening en Docker Compose

Los controles forman parte de backend/compose.yaml y se aplican cada vez que los servicios se crean con Docker Compose.

```
services:
  app:
    user: www-data
    security_opt: [no-new-privileges:true]
    read_only: true
    cap_drop: [ALL]
    cap_add: [NET_BIND_SERVICE]
  db:
    user: mysql
    security_opt: [no-new-privileges:true]
    read_only: true
    cap_drop: [ALL]
```

Figura 5. Controles persistentes en compose.yaml.

- La configuración se aplica con docker compose up -d.
- MySQL permanece sin puerto publicado en el host.

5. Requisito HTTPS para producción

La publicación del servicio se controla mediante APP_BIND y APP_PORT. En Ubuntu Server se expone únicamente el puerto requerido por UFW. Para producción, el tráfico externo debe terminar en un proxy inverso o balanceador con TLS 1.2 o superior, certificado válido y renovación automática.

Requisito	Decisión de despliegue
Exposición	Publicar solo 443/TCP en el proxy; mantener app y MySQL en red privada.
Redirección	Redirigir HTTP a HTTPS y evitar contenido mixto.
Certificado	Usar una autoridad confiable y automatizar renovación y alertas de vencimiento.
Cabeceras	Activar HSTS únicamente después de comprobar HTTPS en todo el dominio.
Origen	Ajustar APP_URL y FRONTEND_ORIGIN al dominio https:// definitivo.
Validación	Healthchecks, auditoría Bash y ZAP registrados en evidencias.

6. Riesgos residuales y limitaciones

• El informe valida el entorno local y no sustituye una revisión del proveedor de alojamiento, firewall, DNS, certificados ni copias de seguridad de producción.

• CAP_NET_BIND_SERVICE permanece en app para conservar el puerto interno 80. Es una concesión mínima y documentada; puede eliminarse si una imagen futura escucha en un puerto no privilegiado.

• Los volúmenes persistentes continúan siendo escribibles por diseño. Su protección depende además de permisos del host, respaldo, cifrado y control de acceso operacional.

• No se afirma ausencia total de vulnerabilidades; se informa únicamente el alcance y las pruebas descritas.

- Los controles quedan definidos en el compose.yaml incluido en la entrega.

7. Integridad de la evidencia

Elemento	SHA-256
backend/compose.yaml	8F917FD28FBC0173F6CFE5E61A5778FDAA54692FF212DA174E425ABB292D128B
output/security-api-hardening.txt	2A7C9084745A0F6C75DD4F041550FC859BDDF1BB2314D3B7147B3E3FC34DA0CE

INTENDENCIA DE SAN JOSÉ

PORTAL VIAL

Informe DAST

Integrantes

Tomás Cabrera · Juan Robaina · Gabriela Romero · Verónica Romero · Juan Corrales

01 | LECTURA EJECUTIVA

Resumen y decisión

El resultado es aceptable para un entorno local de desarrollo, pero no constituye una aprobación de seguridad para producción. ZAP ejecutó un baseline pasivo y no autenticado: observó respuestas y configuración expuesta, pero no intentó explotar la aplicación ni recorrió el panel administrativo con sesión.

Señal	Resultado	Lectura correcta
Baseline ZAP	0 FAIL · 14 WARN · 53 PASS	No hubo reglas configuradas como fallo; permanecen advertencias que requieren triage.
Reporte JSON	17 entradas · 67 instancias	Las 14 reglas se desagregan por variantes (COEP/COOP/CORP y caché).
Severidad ZAP	3 reglas medias · 7 bajas · 4 informativas	No se registraron reglas altas; la prioridad final también considera contexto de negocio.
Nmap	8000/tcp abierto · Apache 2.4.68	La exposición coincide con el servicio esperado, pero revela versión del servidor.

Decisión recomendada

Estado	Condición
PUBLICACIÓN CONDICIONADA	Resolver las prioridades P1, repetir ZAP y conservar el reporte de revalidación.
Uso local/demostración	Permitido dentro del alcance autorizado y sin datos reales.
Producción institucional	No recomendada con este informe como única evidencia; faltan HTTPS, prueba autenticada, API y validación de correcciones.

Prioridades de cierre

- P1. Evitar cualquier fallback GET de los formularios de acceso y confirmar que las credenciales nunca aparecen en la URL.
- P1. Definir una CSP compatible con el portal, protección anti-clickjacking y nosniff en respuestas HTML/estáticas.
- P1. Hospedar localmente Lucide o fijar su versión con Subresource Integrity y crossorigin.
- P2. Ocultar versiones, completar cabeceras cross-origin y validar la política de caché por tipo de recurso.
- P2. Repetir el análisis con sesión, Client Spider y pruebas específicas de API en un entorno autorizado.

Alcance, método y límites

Alcance autorizado

Elemento	Detalle
Objetivo principal	http://host.docker.internal:8000/frontend-publico/
Origen adicional	http://host.docker.internal:8000/ (redirección al portal público)
Contenido explorado	33 URLs informadas por la ejecución del baseline.
Servicio revisado	127.0.0.1:8000 desde contenedor Nmap con red del host.
Fuera de alcance efectivo	Panel IMSJ autenticado, acciones con sesión, cobertura completa de API, fuerza bruta, lógica de negocio, base de datos y pruebas activas.

Procedimiento reproducible

1. Se creó el directorio de evidencia y se ejecutó ZAP Baseline dentro del contenedor oficial estable.
2. ZAP utilizó Automation Framework, spider de hasta un minuto y escaneo pasivo; guardó HTML y JSON.
3. Se ejecutó Nmap TCP Connect con detección de versión únicamente sobre el puerto 8000 local.

```
docker run --rm -v "${PWD}/informes-dast:/zap/wrk:rw" --add-host=host.docker.internal:host-gateway
ghcr.io/zaproxy/zaproxy:stable zap-baseline.py -t http://host.docker.internal:8000/frontend-publico/ -r
zap-report.html -J zap-report.json -I

docker run --rm --network host instrumentisto/nmap -sT -sV -p 8000 127.0.0.1
```

Límites de interpretación

- El parámetro -I evita tratar las advertencias como error de salida; no convierte los WARN en controles aprobados.
- El baseline es principalmente pasivo. No acredita ausencia de SQLi, XSS, fallas de autorización, CSRF ni vulnerabilidades de lógica.
- La aplicación fue analizada por HTTP local. TLS, HSTS y configuración del dominio real deben comprobarse en el entorno de publicación.
- La alerta “Modern Web Application” sugiere usar Client Spider para descubrir rutas dependientes de JavaScript.

Panorama de alertas

La tabla resume las 17 entradas del JSON. La prioridad propuesta no replica mecánicamente la severidad de ZAP: combina exposición, facilidad de corrección y efecto sobre credenciales o ejecución en navegador.

ID	Hallazgo ZAP	Riesgo	Inst.	Prioridad
10038	Content Security Policy (CSP) Header Not Set	Medio	5	P1
10020	Missing Anti-clickjacking Header	Medio	5	P1
90003	Sub Resource Integrity Attribute Missing	Medio	5	P1
10024	Sensitive Information in URL	Info	3	P1 contextual
10021	X-Content-Type-Options Header Missing	Bajo	5	P1
10036	Server version disclosure	Bajo	5	P2
10037	X-Powered-By disclosure	Bajo	2	P2
10017	Cross-Domain JavaScript Source File Inclusion	Bajo	5	P2
90004	COEP Header Missing or Invalid	Bajo	3	P2
90004	COOP Header Missing or Invalid	Bajo	3	P2
90004	CORP Header Missing or Invalid	Bajo	5	P2
10063	Permissions Policy Header Not Set	Bajo	5	P2
10044	Big Redirect Detected	Bajo	2	P3
10027	Suspicious Comments	Info	2	P3 / falso positivo
10109	Modern Web Application	Info	3	Cobertura
10049	Non-Storable Content	Info	4	Revisar
10049	Storable and Cacheable Content	Info	5	Revisar

Distribución por regla única

Nivel ZAP	Reglas	Instancias	Interpretación
Medio	3	15	Controles del navegador ausentes o incompletos.
Bajo	7	35	Endurecimiento, aislamiento de origen y divulgación de información.
Informativo	4	17	Cobertura, caché y señales que necesitan validación manual.

Controles del navegador

DAST-01	Content Security Policy no definida	MEDIO
Observación	ZAP detectó ausencia de CSP en cinco respuestas, incluidas la raíz, el portal, estudio, login y noticias.	
Impacto	Sin una política explícita, un XSS o recurso manipulado dispone de mayor libertad para cargar scripts, estilos o destinos externos.	
Acción recomendada	Definir CSP inicialmente en modo Report-Only, observar incompatibilidades y luego aplicar una política restrictiva. Evitar unsafe-inline cuando sea posible y limitar script-src a orígenes necesarios.	
Criterio de cierre	Las páginas HTML responden con una CSP efectiva, la interfaz conserva su funcionalidad y ZAP ya no informa 10038.	

DAST-02	Protección anti-clickjacking ausente	MEDIO
Observación	Cinco páginas no enviaron X-Frame-Options ni una directiva CSP frame-ancestors equivalente.	
Impacto	Un sitio externo podría embeber la interfaz y engañar a una persona para interactuar con controles superpuestos.	
Acción recomendada	Preferir CSP frame-ancestors 'none' o una lista institucional mínima. Agregar X-Frame-Options: DENY como compatibilidad si el portal no necesita ser embebido.	
Criterio de cierre	Las respuestas HTML bloquean el embeber no autorizado y ZAP ya no informa 10020.	

DAST-03	Recursos de terceros sin verificación de integridad	MEDIO
Observación	ZAP registró cinco instancias y el código carga Lucide desde unpkg. El análisis SAST existente ya había señalado el mismo patrón en ocho páginas.	
Impacto	Una alteración del recurso o de su cadena de entrega podría ejecutar JavaScript bajo el origen del portal.	
Acción recomendada	Opción preferida: alojar una copia aprobada dentro del proyecto. Alternativa: fijar versión, hash SRI y atributo crossorigin, verificando que el proveedor entregue contenido inmutable.	
Criterio de cierre	No quedan scripts externos sin integridad; ZAP 90003 y la regla SAST correspondiente desaparecen sin pérdida de iconos.	

Credenciales y cabeceras

DAST-04	Posible exposición de credenciales en URL	ALTA CONTEXTUAL
Observación	ZAP observó tres URL de login con parámetros cedula, password y password_confirm. Los formularios HTML no declaran método; JavaScript cancela el envío y usa POST, pero un fallo, bloqueo o carga incompleta del script deja disponible el comportamiento GET por defecto.	
Impacto	Las URL pueden persistir en historial, registros, herramientas de monitoreo o cabeceras Referer. Aunque los valores ZAP eran sintéticos, el patrón es relevante para credenciales reales.	
Acción recomendada	Declarar explícitamente method='post' en los tres formularios y una acción segura o fallback que no exponga secretos. Mantener el envío API por POST y probar el comportamiento con JavaScript deshabilitado o fallido.	
Criterio de cierre	Ninguna navegación, log ni captura contiene contraseñas en query string; ZAP 10024 desaparece y las pruebas negativas confirman que GET no procesa credenciales.	

DAST-05	X-Content-Type-Options ausente en contenido web	BAJO
Observación	Cinco respuestas públicas, incluido CSS e imagen, no devolvieron X-Content-Type-Options: nosniff. La API sí define esta cabecera en sus respuestas JSON y archivos.	
Impacto	Algunos navegadores pueden interpretar un contenido con un tipo distinto al declarado, ampliando el efecto de cargas o respuestas mal configuradas.	
Acción recomendada	Configurar la cabecera en Apache para portal y panel, sin limitarla a las respuestas del backend PHP. Confirmar tipos MIME correctos.	
Criterio de cierre	Todas las respuestas estáticas y dinámicas incluyen nosniff y ZAP ya no informa 10021.	

DAST-06	Versiones y tecnología expuestas	BAJO
Observación	Nmap identificó Apache httpd 2.4.68 y ZAP detectó Server y X-Powered-By en varias respuestas, incluidas páginas 404.	
Impacto	La información reduce el trabajo de reconocimiento de un atacante y facilita asociar vulnerabilidades conocidas a versiones visibles.	
Acción recomendada	Aplicar ServerTokens Prod, ServerSignature Off y expose_php=Off. Mantener parches del contenedor y verificar también respuestas de error.	
Criterio de cierre	Las respuestas no revelan versión ni X-Powered-By; Nmap identifica el servicio sin una versión innecesariamente precisa.	

Observaciones agrupadas

Grupo	Evidencia	Riesgo	Tratamiento recomendado
Aislamiento cross-origin	COEP 3, COOP 3 y CORP 5 instancias	Bajo	Definir políticas solo después de inventariar recursos, ventanas y documentos compartidos; probar compatibilidad del portal.
Permissions-Policy	5 respuestas sin cabecera	Bajo	Deshabilitar capacidades del navegador no utilizadas (por ejemplo cámara, micrófono y geolocalización) y habilitar únicamente las justificadas.
JavaScript de otro dominio	5 páginas con fuente cross-domain	Bajo	Resolver junto con DAST-03: recurso local o proveedor fijado, SRI y CSP.
Redirecciones grandes	2 respuestas 302	Bajo	Conservar redirecciones simples y sin cuerpo sensible. Validar que Location no dependa de entrada externa.
Caché	4 no almacenables y 5 almacenables	Info	Distinguir HTML público, archivos estáticos y respuestas con identidad. Aplicar no-store a datos sensibles y versionado/max-age a recursos públicos.
Comentarios sospechosos	2 coincidencias en api.js	Info	Triage manual: la evidencia corresponde a una frase en español que contiene la secuencia “Retira”; parece falso positivo de la regla TODO. Conservar como revisado.
Aplicación moderna	3 instancias	Info	No es una vulnerabilidad. Usar Client Spider para mejorar la cobertura de rutas controladas por JavaScript.

Relación con la configuración observada

- backend/apache.conf limita índices y publica únicamente las rutas previstas, pero no define todavía el conjunto de cabeceras del portal.
- backend/core/Response.php ya envía no-store y nosniff para JSON; la corrección debe extenderse a HTML, CSS, JavaScript, imágenes y errores de Apache.
- frontend-publico/js/login.js cancela el submit y frontend-publico/js/api.js usa POST; el HTML debe conservar una defensa segura incluso si ese JavaScript no se ejecuta.

Exposición de red

Activo	Resultado Nmap	Evaluación
127.0.0.1:8000/tcp	open · http · Apache httpd 2.4.68	Servicio esperado en el entorno local. No se evaluaron otros puertos ni exposición externa.

07 | PLAN DE ACCIÓN

Corrección y revalidación

Orden	Acción	Responsable sugerido	Evidencia de cierre
1 · P1	Asegurar POST/fallback de los formularios y eliminar credenciales de URL.	Frontend + backend	Prueba con JS activo/inactivo; logs e historial sin secretos; ZAP 10024 ausente.
2 · P1	Aplicar CSP, anti-clickjacking y nosniff en Apache.	Infraestructura	Cabeceras verificadas en 200, 302, 404 y API; interfaz sin regresiones.
3 · P1	Eliminar dependencia remota o agregar SRI/crossorigin.	Frontend	ZAP/SAST limpios para integridad y carga cross-domain.
4 · P2	Ocultar versiones y X-Powered-By.	Infraestructura	ZAP 10036/10037 ausentes; Nmap sin versión detallada.
5 · P2	Definir Permissions-Policy, políticas cross-origin y caché.	Arquitectura + infraestructura	Matriz de compatibilidad y nueva ejecución sin alertas no aceptadas.
6 · Cobertura	Ejecutar Client Spider y sesión de prueba sobre panel/API.	Seguridad / QA	Reporte autenticado, rutas cubiertas, usuarios de prueba y límites documentados.

Guion mínimo de revalidación

- Ejecutar la misma línea base contra el mismo corte de código y conservar HTML, JSON, consola y fecha.
- Comparar por identificador de regla: nuevo, persistente, corregido o aceptado con justificación.
- Comprobar manualmente cabeceras en 200, redirecciones y errores; revisar que CSP no rompa iconos, navegación ni formularios.
- Confirmar que login y registro no generan query strings con claves, aun si JavaScript no carga.
- Añadir escaneo autenticado de panel/API con cuentas de rol acotado y datos sintéticos.

Criterio de aceptación propuesto

Condición	Umbral
Hallazgos P1	0 abiertos
Alertas medias nuevas	0, salvo aceptación explícita documentada
Credenciales en URL	0 instancias y prueba negativa aprobada
Regresiones funcionales	0 en navegación, login, registro e iconos
Trazabilidad	Commit, fecha, comandos, reportes y capturas conservados

08 | EVIDENCIA

Ejecución del baseline ZAP

La captura registra la creación del directorio, descarga de la imagen oficial estable, inicio del Automation Framework, total de 33 URLs y controles PASS iniciales.

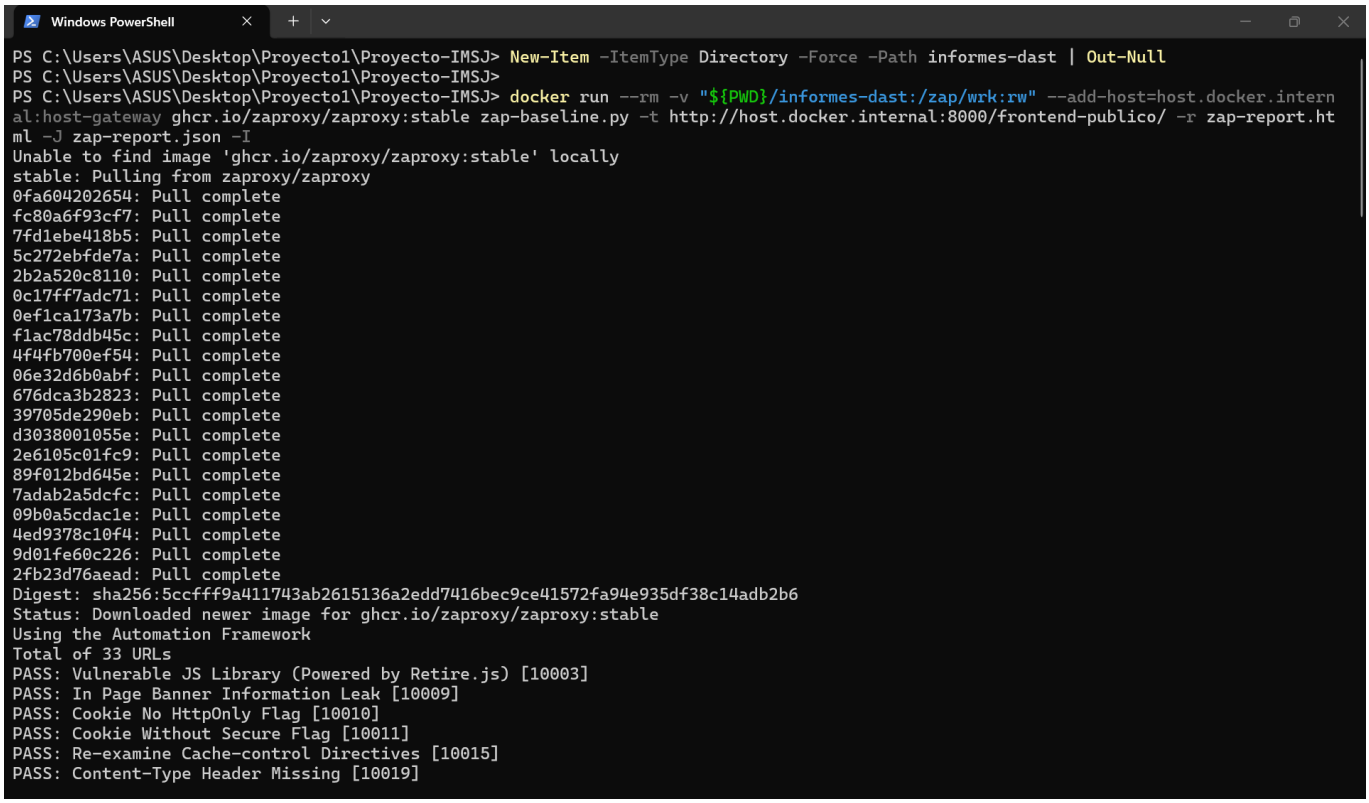


Figura 1. Inicio y progreso del escaneo ZAP Baseline, 20/10/2026.

Dato verificable	Valor
Imagen	Captura de pantalla 2026-10-20 170835.png
Comando	zap-baseline.py con salida HTML y JSON
Objetivo	http://host.docker.internal:8000/frontend-publico/
Contexto	Contenedor con host.docker.internal resuelto mediante host-gateway

09 | EVIDENCIA

Alertas y resumen del baseline

La salida final muestra ejemplos de políticas ausentes y el resumen consolidado: 0 FAIL, 14 WARN y 53 PASS. Ese resultado se corresponde con las 14 reglas únicas registradas en el JSON.

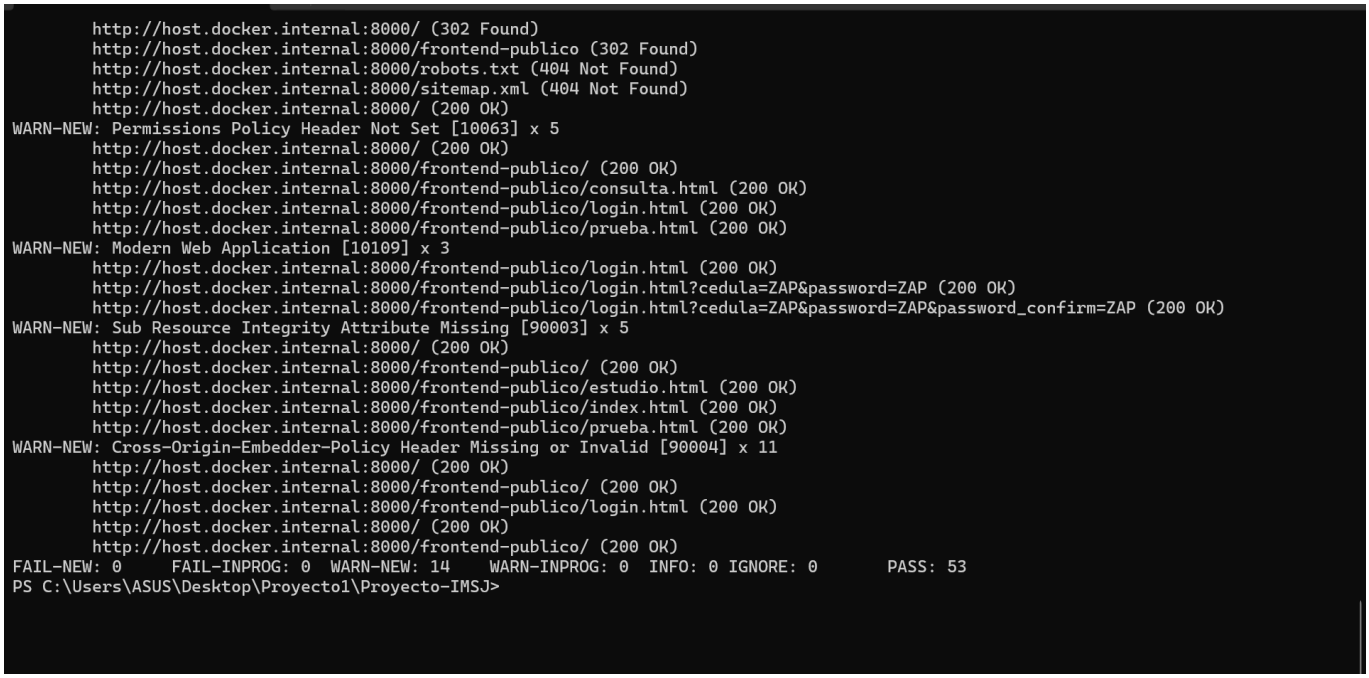


Figura 2. Tramo final del baseline y resumen de resultados, 20/10/2026.

Indicador	Resultado
FAIL-NEW / FAIL-INPROG	0 / 0
WARN-NEW / WARN-INPROG	14 / 0
INFO / IGNORE / PASS	0 / 0 / 53
Lectura	El baseline terminó sin fallos de política, pero requiere triage y revalidación de advertencias.

10 | EVIDENCIA

Reconocimiento Nmap y procedencia

Nmap confirmó que el host local estaba activo y que el puerto previsto publicaba HTTP mediante Apache. El análisis se limitó expresamente a 8000/tcp.

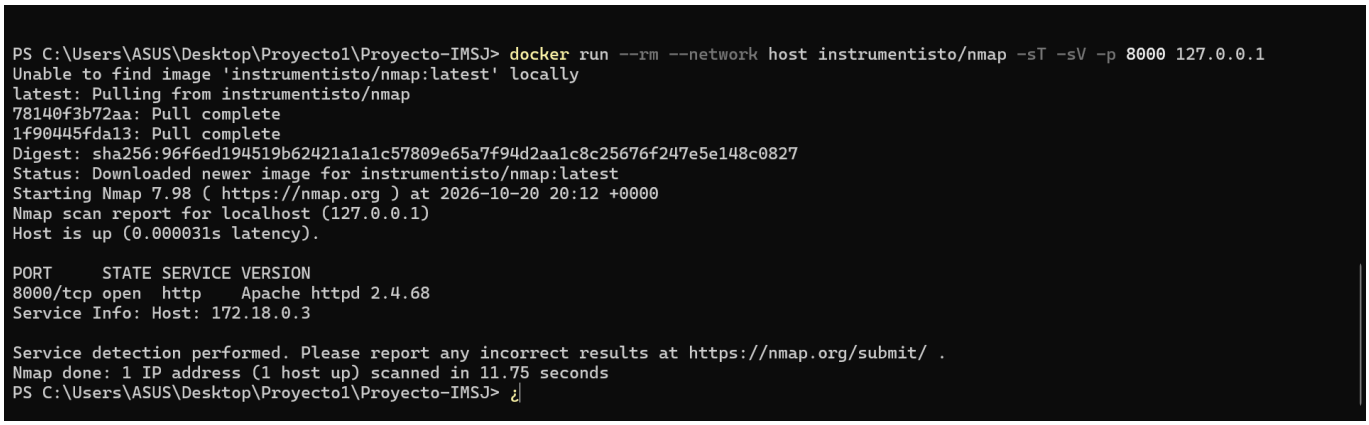


Figura 3. Detección de servicio en 127.0.0.1:8000, 20/10/2026.

Campo	Resultado
Host	localhost (127.0.0.1), activo
Puerto	8000/tcp open
Servicio	http
Versión detectada	Apache httpd 2.4.68
Duración informada	11,75 segundos

Integridad de los artefactos fuente

Archivo	SHA-256
zap-report.json	2F7FE678713736987E4A62582A2FC79A2F193EF0262FD6250580D03CDB9EBFF4
zap-report.html	7BD21A6FE2B7E45D8FCC427CEF4775D4D8604C65DBA92BC3F860668B9BB9FD16
nmap-report.txt	3CE3FF369040DD970C539DD70D7369BE4979B08F930938D99A784FDE8DBA8F96

11 | CIERRE

Conclusiones y referencias

Conclusión

El DAST confirmó una superficie local coherente con el diseño esperado y no registró fallos de política ni hallazgos ZAP de severidad alta. Sin embargo, evidenció controles de navegador y endurecimiento que deben completarse. La condición más delicada es la posibilidad de que los formularios recurran a GET si el JavaScript no intercepta el envío; su corrección es pequeña y reduce un riesgo desproporcionado sobre credenciales.

El informe no afirma que la aplicación esté libre de vulnerabilidades. Para cerrar el ciclo se necesita aplicar las medidas P1, repetir el baseline y ampliar la cobertura a rutas autenticadas, panel, API y navegación dinámica. La publicación institucional también requiere HTTPS y la configuración real del dominio.

Referencias técnicas

Referencia	Uso en este informe
OWASP ZAP 2.17.0 · reporte tradicional JSON/HTML	Fuente primaria de alertas, instancias, severidad y confianza.
ZAP Baseline Scan	Interpretación del escaneo pasivo, WARN/FAIL y límites de cobertura.
OWASP Secure Headers Project	CSP, anti-clickjacking, nosniff, políticas cross-origin y permissions policy.
MDN Web Docs · Subresource Integrity	Tratamiento de recursos externos con integrity y crossorigin.
Nmap 7.98	Identificación del puerto y versión del servicio local.
Código del proyecto · commit 5f15b3b	Validación contextual de formularios, cliente API y configuración Apache.

Artefactos conservados

- informes-dast/zap-report.html — reporte navegable generado por ZAP.
- informes-dast/zap-report.json — fuente estructurada utilizada para el triage.
- informes-dast/nmap-report.txt — salida textual del reconocimiento de servicio.
- Capturas de ejecución incorporadas en las páginas 9 a 11 de este informe.

FIN DEL INFORME

Revalidación posterior a correcciones

OWASP ZAP Baseline y Nmap se ejecutaron nuevamente el 21/10/2026 contra el contenedor reconstruido desde el árbol de trabajo del proyecto. La verificación previa confirmó CSP, anti-clickjacking, nosniff, políticas cross-origin, Permissions-Policy y caché diferenciada.

14	4	0	63
reglas con alerta iniciales	reglas con alerta posteriores	fallos de política	controles aprobados

Controles corregidos

Hallazgo inicial	Tratamiento comprobado	Estado
CSP y anti-clickjacking	Content-Security-Policy con frame-ancestors y X-Frame-Options: DENY.	Cerrado
Script externo sin integridad	Lucide fue sustituido por iconos SVG locales.	Cerrado
Credenciales en URL	Los tres formularios declaran POST; no aparecieron query strings con claves.	Cerrado
nosniff y políticas del navegador	Se añadieron X-Content-Type-Options, COOP, COEP, CORP y Permissions-Policy.	Cerrado
Divulgación tecnológica	X-Powered-By se elimina y Nmap informa Apache httpd sin versión.	Cerrado
JavaScript de terceros	No quedan scripts externos en el portal revisado.	Cerrado

Decisión posterior

Los hallazgos prioritarios P1 del baseline inicial quedaron cerrados. El resultado posterior fue 0 FAIL, 4 WARN y 63 PASS. Las advertencias restantes se sometieron a triage y no muestran una vía de explotación confirmada en el alcance pasivo y no autenticado ejecutado.

Triage de advertencias restantes

El JSON posterior contiene 5 entradas, 12 instancias y cuatro identificadores de regla únicos. La diferencia se debe a que ZAP representa dos decisiones de caché bajo el mismo identificador 10049.

Regla	Evidencia posterior	Clasificación del equipo
10202 - Ausencia de token anti-CSRF	3 formularios de login/registro.	No aplicable al flujo revisado: la API no autentica con cookies, exige JSON y usa token Bearer en sessionStorage. Los formularios son una defensa POST si falla JavaScript.
10027 - Comentarios sospechosos	2 instancias en api.js; evidencia: 'etira del navegador...'.	Falso positivo lingüístico por la palabra 'Retira'; no contiene secretos, tareas pendientes ni información operativa.
10109 - Aplicación web moderna	1 señal por scripts del login.	Informativa. Justifica Client Spider para ampliar cobertura; no requiere corrección.
10049 - Caché	5 respuestas no almacenables y 1 CSS cacheable.	Comportamiento esperado: HTML y errores usan no-store; CSS público usa max-age=3600 y no contiene datos personales.

Nmap posterior

Objetivo	Resultado	Lectura
host.docker.internal:8000	open - http - Apache httpd	Único puerto incluido en el alcance; la versión 2.4.68/2.4.69 ya no se divulga.

Límite que permanece

Esta revalidación confirma el baseline público y el reconocimiento del puerto 8000. No sustituye una prueba autenticada del panel, Client Spider, auditoría específica de la API ni pruebas activas de lógica de negocio. Esas actividades deben mantenerse separadas y ejecutarse solo con cuentas y datos de prueba.

Evidencia posterior

Figura 4. Resumen final de OWASP ZAP: 0 FAIL, 4 WARN y 63 PASS.

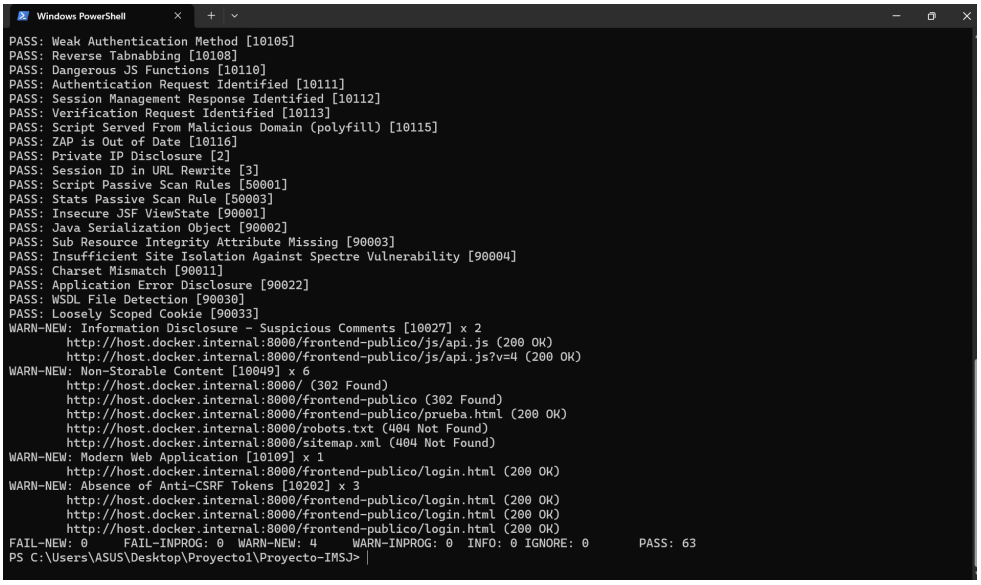
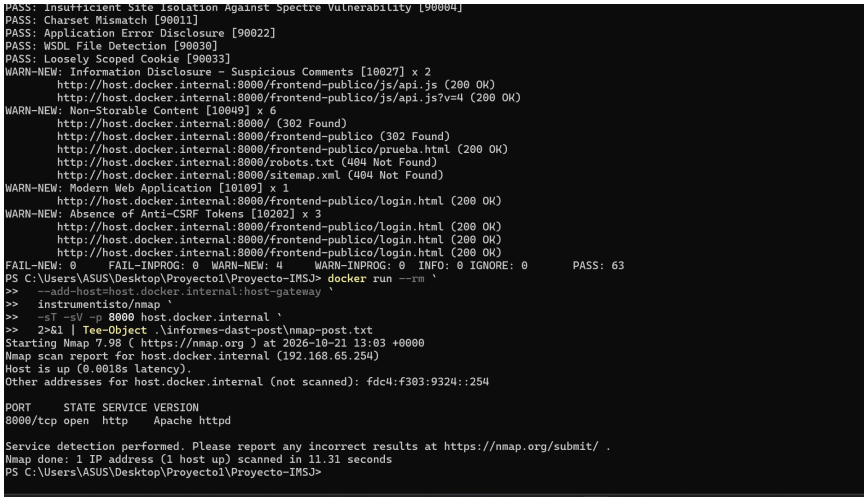


Figura 5. Nmap confirma el puerto 8000 y oculta la versión exacta de Apache.



Integridad de artefactos posteriores

Artefacto	SHA-256
zap-report-post.json	316C4AE7D043A11A9F6BC21A3FC4A3A12AFA12E7F54FB13E23DFA16BDCD54F30
zap-report-post.html	4FA956EEB6DB097F18BBEBB6FF6350B2ECC757A87D3DBCAD392A0C1D4B750E31
zap-post-terminal.txt	9831E979C6DDDDB785AB92357717E87FF56F2074397E8A7F270818CCA1764FB5
nmap-post.txt	11CEC12C79378F827037A061A73CFDAABE7BF80008E77A33A982C2C64B41D7F1

INTENDENCIA DE SAN JOSÉ

PORTAL VIAL

Auditoría Bash de la API

Integrantes

Tomás Cabrera · Juan Robaina · Gabriela Romero · Verónica Romero · Juan Corrales

1. Resumen ejecutivo

Se ejecutó una auditoría automatizada de seguridad sobre la API REST del Proyecto IMSJ en un entorno local expresamente autorizado. La validación combinó controles sin autenticación, sesiones válidas e inválidas, perfiles PUBLICO_GENERAL, PERSONAL_IMSJ y DIRECTORA, datos descartables y casos negativos diseñados para confirmar que la API rechaza operaciones inseguras de forma controlada.

43	0	0	0
Aprobadas	Fallidas	Omitidas	Código de salida

1.1 Objetivo

Obtener evidencia reproducible de que los controles principales de la API funcionan ante solicitudes válidas y maliciosas controladas, y que una ejecución incompleta o con fallos produce un código distinto de cero.

1.2 Alcance y límites

Incluido	Fuera de alcance
API local en 127.0.0.1:8000; autenticación y sesiones; autorización por rol; CORS; cabeceras; archivos; rutas privadas; SQLi/XSS; rate limiting; IDOR de reservas; limpieza de datos.	Infraestructura productiva, HTTPS público, ingeniería social, denegación de servicio sostenida, dispositivos de usuarios y servicios de terceros.

Todas las cédulas visibles en las capturas son identificadores ficticios de prueba. Las contraseñas se introdujeron de forma oculta y no se conservaron en el informe.

2. Metodología y controles

El script realiza peticiones HTTP con curl, compara el código obtenido con el esperado, inspecciona respuestas y encabezados, cuenta resultados y finaliza con estado no cero ante una falla. En modo estricto también falla si queda una prueba omitida. Las operaciones de escritura se limitaron a registros descartables eliminados al finalizar.

Área	Comprobaciones principales	Criterio de aceptación
Disponibilidad	API y healthcheck	HTTP 200 y estado ok
Cabeceras	nosniff, caché, anti-clickjacking, CSP y Server	Controles presentes; sin versión exacta
Autenticación	Sin token, token inválido, válido, revocado y expirado	401 para sesiones no válidas; 200 para sesión válida
Autorización	Panel por rol, aprobación y reserva ajena	403 por rol insuficiente; 404 para recurso ajeno
Entradas	JSON inválido, SQLi y XSS controlados	400/422; sin 500, eco de payload ni ejecución
Archivos	PHP presentado como PDF	422 y ausencia de ejecución
CORS	Origen permitido y origen ajeno	204 permitido; 403 ajeno; origen único
Exposición	.env, config.php, SQL y traversal	404 sin contenido privado
Abuso	Intentos repetidos de login	429 dentro del límite configurado

2.1 Preparación controlada

- Objetivo limitado a la instancia local autorizada; no se realizaron pruebas contra sistemas externos.
- Credenciales solicitadas interactivamente y contraseña oculta en terminal.
- FAQ, usuarios, tokens, franja y reserva creados exclusivamente para comprobar permisos y propiedad.
- Los registros descartables se eliminaron y se verificó que no permanecieran usuarios ni franjas de la preparación final.
- El modo estricto IMSJ_SECURITY_REQUIRE_FULL=1 exigió cero omisiones para aceptar la ejecución final.

3. Resultados y trazabilidad

Ejecución	Rol / propósito	Aprobadas	Fallidas	Omitidas	Salida	Interpretación
security-api-publico.txt	PUBLICO_GENERAL	32	0	4	0	Cobertura del ciudadano; omisiones esperadas por rol
security-api-directora.txt	DIRECTORA	37	0	3	0	Carga maliciosa y 429 confirmados
security-api-personal.txt	PERSONAL_IMSJ	35	0	3	0	Flujo descartable y 403 de aprobación
security-api-final.txt	Aceptación estricta	43	0	0	0	Cobertura completa; resultado final válido

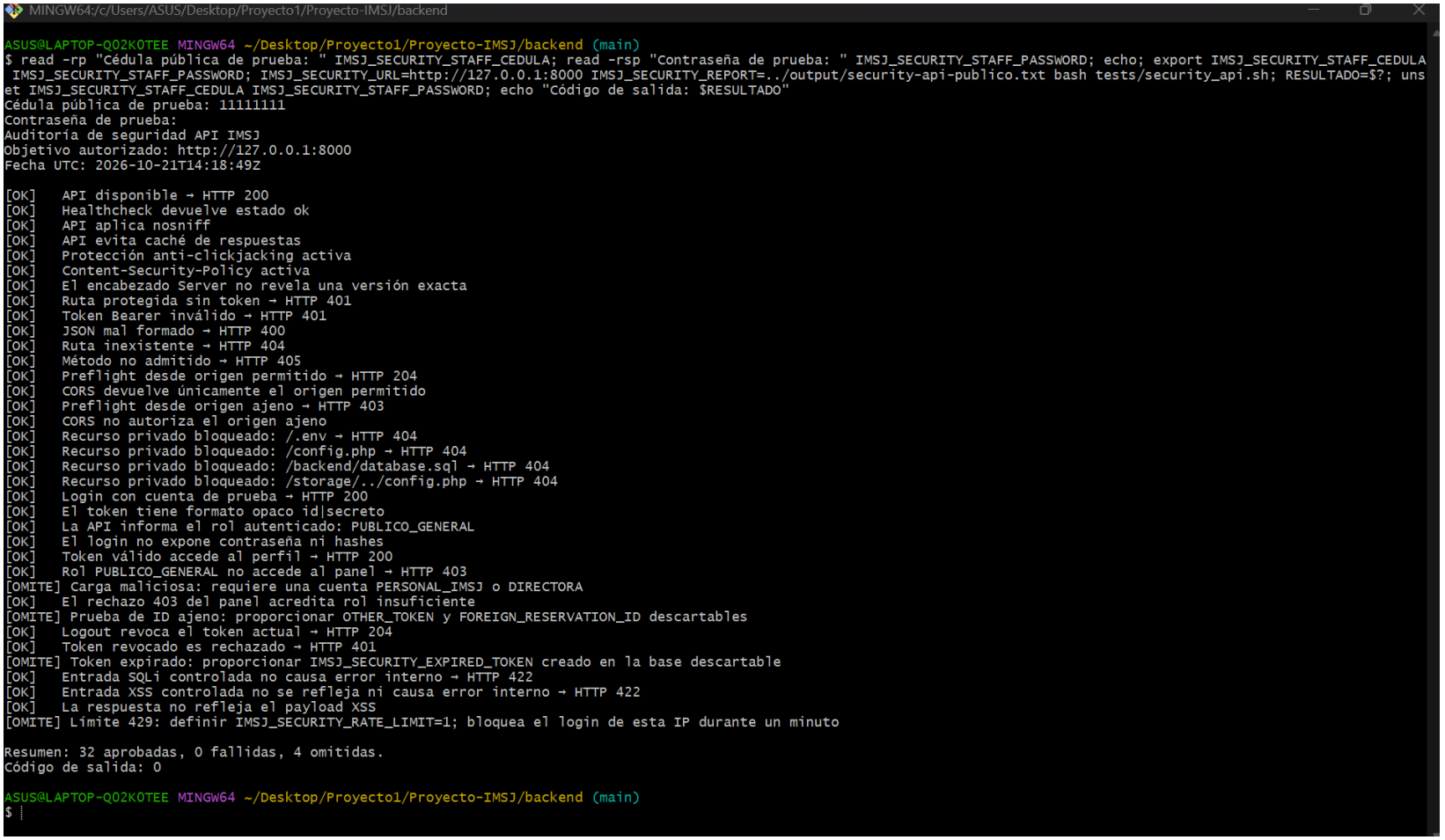
3.1 Interpretación

- No se confirmó ninguna falla de seguridad dentro del alcance automatizado de la ejecución estricta final.
- La respuesta 404 ante una reserva de otro usuario evita revelar su existencia y bloquea la cancelación ajena.
- Los tokens revocado y expirado fueron rechazados con 401; el token válido accedió al perfil con 200.
- El archivo PHP disfrazado de PDF fue rechazado con 422, validando que la extensión declarada no basta para aceptar una carga.
- La cuenta PERSONAL_IMSJ pudo preparar contenido, pero recibió 403 al intentar una acción reservada a DIRECTORA.
- El quinto intento controlado activó 429, confirmando el límite de solicitudes de autenticación.

3.2 Incidencia de ejecución no atribuible a la API

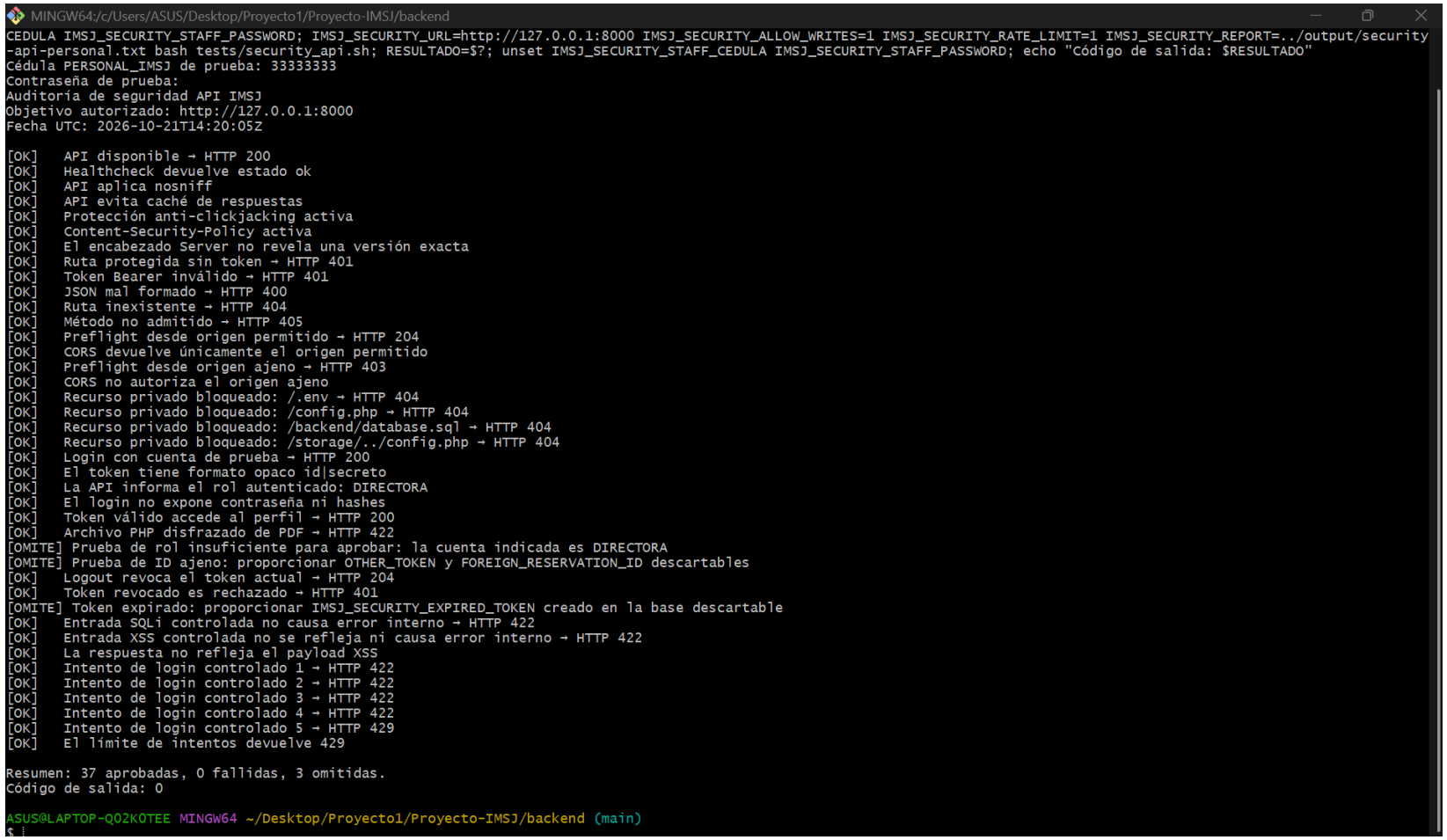
Durante la preparación de la evidencia completa, una primera cadena de consola no separó correctamente tres identificadores devueltos por MySQL. El modo estricto detectó la omisión del caso IDOR y terminó con código 2. Se corrigió el separador de la preparación, se recrearon los datos descartables y se repitió toda la auditoría. La aceptación se basa exclusivamente en la repetición final 43/0/0 con código 0.

Evidencia 1 - Perfil PUBLICO_GENERAL



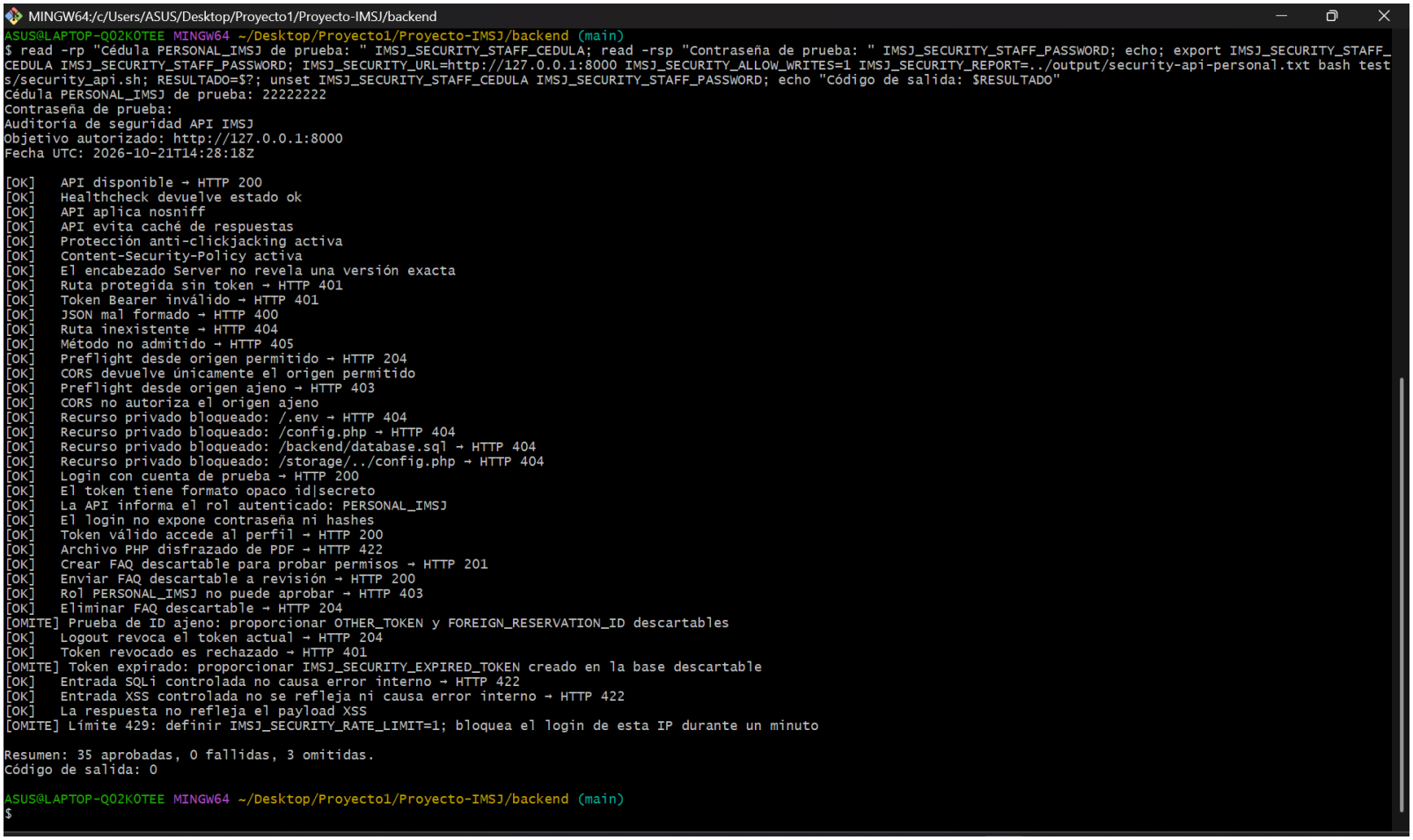
Ejecución autenticada con rol ciudadano: 32 pruebas aprobadas, 0 fallidas y salida 0. Los casos omitidos corresponden a controles que requieren otro rol o preparación específica.

Evidencia 2 - Perfil DIRECTORA



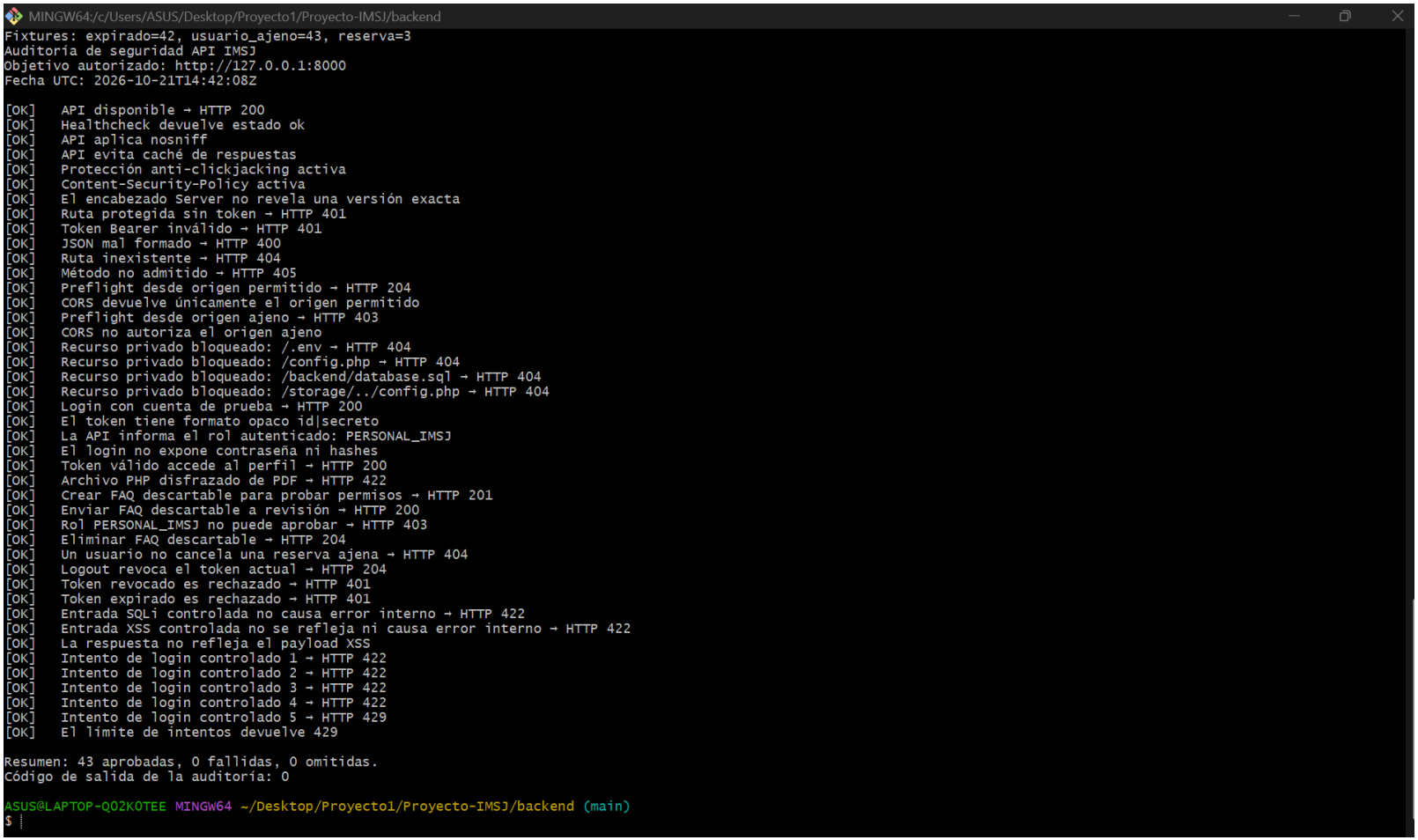
Ejecución con rol DIRECTORA: 37 pruebas aprobadas, 0 fallidas y salida 0. Se observa el rechazo de un archivo PHP presentado como PDF y el límite HTTP 429.

Evidencia 3 - Perfil PERSONAL_IMSJ



Ejecución con rol PERSONAL_IMSJ: 35 pruebas aprobadas, 0 fallidas y salida 0. Incluye creación y eliminación de una FAQ descartable y rechazo 403 al intentar aprobarla.

Evidencia 4 - Ejecución estricta final



Cierre de aceptación: 43 pruebas aprobadas, 0 fallidas, 0 omitidas y código de salida 0. Incluye token expirado, token revocado, reserva ajena, carga maliciosa y límite de intentos.

4. Integridad de la evidencia

Artefacto	SHA-256
backend/tests/security_api.sh	24f4854e64186eea009f900368bfd8f8fd2d265e399e53ed5a3cb8aed544714d
output/security-api-final.txt	e9e884a49368782da1c4e08b346b97291da03549d17b81f8c7504e507ae7798e

5. Limitaciones

- El informe documenta una ejecución local; no acredita la configuración TLS/HTTPS de un despliegue productivo.
- Las pruebas automáticas reducen riesgo, pero no demuestran ausencia absoluta de vulnerabilidades.
- Las ejecuciones parciales por rol contienen omisiones previstas; la conclusión técnica se apoya en la ejecución estricta final sin omisiones.
- El snapshot evaluado parte del commit 5f15b3b e incluye cambios locales; antes de la entrega debe asociarse esta evidencia al commit o tag definitivo.

6. Conclusión

La auditoría Bash de seguridad de la API REST IMSJ cumple su criterio técnico de cierre. La ejecución final verificó todos los controles programados sin fallas ni omisiones y produjo código de salida 0. Las respuestas observadas fueron coherentes con la política de autenticación, autorización, validación de entradas, protección de archivos, CORS y limitación de intentos.

DICTAMEN: APROBADO dentro del alcance local autorizado y sujeto a vincular la evidencia con la versión final entregada.

Elaborado por	Revisado por	Fecha de aprobación
Equipo Proyecto IMSJ	_____	_____

INTENDENCIA DE SAN JOSÉ

PORTAL VIAL

Registro de hallazgos

Integrantes

Tomás Cabrera · Juan Robaina · Gabriela Romero · Verónica Romero · Juan Corrales

Registro consolidado de hallazgos y controles

Proyecto: Educación Vial IMSJ - Portal Vial. **Corte documental:** 21/10/2026.

1. Fuentes y alcance

Fuente	Alcance y referencia
Semgrep 1.180.0	JSON posterior y salida de terminal.
ZAP 2.17.0	Baseline de `http://host.docker.internal:8000`; JSON y terminal.
Nmap 7.98	Registro de 8000/tcp, 21/10/2026 a las 13:03 UTC.
Auditoría Bash	Resultado final, 21/10/2026 a las 14:42:08 UTC.
Integración HTTP/MySQL	192 comprobaciones, 21/10/2026 a las 14:47:36 UTC.

El registro separa los avisos de las herramientas del análisis de su contexto y de los resultados de pruebas. Las severidades WARNING y ERROR pertenecen al formato de Semgrep; el riesgo de ZAP utiliza su escala propia.

2. Análisis estático

El JSON de Semgrep contiene seis resultados y un diagnóstico de análisis parcial.

ID	Aviso registrado	Ubicación del informe	Análisis del código consultado
HS-01	tainted-filename; WARNING	core/Auth.php:62	El contador genera el nombre mediante SHA-256 de operación e IP, agrega `.json` y lo ubica bajo CACHE_ROOT. La entrada no se utiliza como URL ni como nombre de ruta directo.
HS-02	unlink-use; WARNING	models/Archivo.php:80	La eliminación descarta URL remotas, resuelve las rutas con realpath y exige que el archivo permanezca bajo UPLOAD_ROOT antes de llamar a unlink.
HS-03	exec-use; ERROR	scripts/verificar.php:23	El rango señalado corresponde a proc*open con un arreglo de argumentos: PHP*BINARY, -l y la ruta de un PHP encontrado bajo backend. El archivo exige ejecución CLI. El análisis considera ese origen de argumentos y las condiciones de acceso al script.
HS-04	django-no-csrf-token; WARNING	Login.html:33	Regla de plantillas Django aplicada al formulario de ingreso ciudadano de una aplicación PHP/JavaScript.
HS-05	django-no-csrf-token; WARNING	Login.html:48	Misma regla aplicada al registro ciudadano.
HS-06	django-no-csrf-token; WARNING	Login.html:71	Misma regla aplicada al ingreso administrativo.
HS-07	PartialParsing; diagnóstico	Dockerfile:5-18	El analizador informa una lectura parcial del archivo; la evaluación de contenedores se complementa con Compose, salud y auditoría HTTP.

Fuentes del análisis: Auth, Archivo, verificador CLI, formularios, cliente de acceso y Dockerfile.

En HS-03, exec-use identifica la regla de la herramienta. La ubicación del aviso coincide con la llamada proc_open del verificador. Los hashes de integración identifican ese archivo; la revisión del contexto contempla argumentos separados, ejecución CLI y acceso de escritura al árbol de código.

Control de revisión SAST	Referencia
JSON con los seis avisos	semgrep-post.json.
Fuente actual identificada por hashes	integracion-final.json.

Control de revisión SAST	Referencia
Tratamiento propuesto de HS-03	Conservar el verificador CLI con argumentos separados; restringir escritura del código y revisar el aviso al modificar la ejecución de procesos. No se declara corregido ni falso positivo por decisión humana.

3. Análisis dinámico

El JSON de ZAP registra la generación del informe el 21/10/2026 a las 13:03:26, versión 2.17.0. Su campo de fecha no incluye zona horaria.

ID	Tipo de alerta	Riesgo de ZAP	Instancias	Contexto de evaluación
HD-01	Ausencia de token anti-CSRF	Medio, código 2	3	Formularios de la pantalla de acceso. El cliente JavaScript envía JSON y usa Bearer explícito para las operaciones autenticadas.
HD-02	Comentarios sospechosos	Informativo, código 0	2	Detección pasiva de texto en las respuestas.
HD-03	Aplicación web moderna	Informativo, código 0	1	Identificación de una interfaz con comportamiento JavaScript.
HD-04	Contenido no almacenable	Informativo, código 0	5	Respuestas con instrucciones de caché observadas por el análisis.
HD-05	Contenido almacenable en caché	Informativo, código 0	1	Recurso que puede conservar el navegador según sus cabeceras.

El resumen de terminal registra **0 FAIL, 4 WARN y 63 PASS**. Esos contadores son categorías del baseline; el JSON organiza sus resultados por tipo de alerta e instancia.

La configuración de Apache establece `no-store` para HTML y permite caché de una hora para recursos estáticos. La respuesta de API establece las cabeceras de sus respuestas. La auditoría Bash comprueba CSP, nosniff, anti-clickjacking y ausencia de caché en API.

La alerta CSRF se interpreta según la forma real de enviar credenciales y las operaciones públicas de login, registro y consultas. La coincidencia con una regla de Django o la existencia de un Bearer se analizan junto con ese flujo. El baseline público conserva su propio alcance, distinto de una exploración autenticada del panel.

4. Exposición y contenedores

Nmap registra Apache HTTP abierto en 8000/tcp en el objetivo local utilizado para la prueba. Compose permite definir la dirección y el puerto mediante `APP_BIND` y `APP_PORT`, y mantiene MySQL sin puerto publicado en el host.

Control	Configuración o prueba
Cuenta de aplicación	www-data.
Cuenta de base	mysql.
Sistema de archivos raíz	Solo lectura en ambos servicios.
Escalamiento de privilegios	no-new-privileges en ambos servicios.
Capacidades	Se descartan todas; app agrega NET*BIND*SERVICE.
Escritura	Volúmenes persistentes y temporales tmpfs declarados.
Separación de publicación	Raíz PHP en public; alias de frontends de solo lectura.
Rutas privadas	La auditoría rechaza .env, config.php, SQL y recorrido fuera de storage con 404.

5. Controles revalidados mediante API

Grupo	Evidencia concreta
Sesiones	Token válido, inválido, revocado y vencido; ocultamiento de contraseña y hashes.
Roles	PERSONAL_IMSJ recibe 403 al intentar aprobar una FAQ pendiente.
Propiedad	Una cuenta no puede cancelar una reserva ajena; respuesta 404.
Archivos	Un PHP presentado como PDF se rechaza con 422.
Entradas	JSON mal formado 400; entradas SQLi/XSS controladas 422 y sin reflejo del payload XSS.
CORS	Preflight permitido 204; origen ajeno 403 y sin autorización CORS.
Métodos y rutas	Método no admitido 405; ruta inexistente 404 en los casos evaluados.
Rate limit	La secuencia de acceso controlada alcanza 429.
Transacciones	La integración provoca un fallo de auditoría y comprueba rollback del material y limpieza del PDF nuevo.

La ejecución API final registra 43 aprobadas sin fallos ni omisiones. La integración registra OK para sus 192 comprobaciones. Los controles ejecutados se conservan junto a los avisos automáticos y a las condiciones institucionales del checklist.

6. Reflexión ética

Las pruebas documentadas apuntan al entorno local del proyecto. La suite de integración exige una base aislada y utiliza registros sintéticos. La auditoría distingue operaciones de lectura y opciones de escritura, y su resultado identifica los escenarios ejecutados y omitidos.

Los registros que se comparten deben conservar fecha, alcance, versión y resultado, evitando publicar secretos o datos de personas reales. La revisión de una alerta debe atender a la ruta de datos y a la posibilidad de reproducirla. El texto del análisis conserva los contadores originales para que otra persona pueda contrastarlos.

Los controles de la aplicación y los procedimientos del organismo se complementan: dominio HTTPS, retención, contacto y operación posterior deben definirse antes de publicar el sistema.

7. Referencias

Informe SAST, informe DAST, auditoría Bash, hardening, plan e informe de pruebas, respuesta a incidentes y reflexión ética.

INTENDENCIA DE SAN JOSÉ

PORTAL VIAL

Respuesta a incidentes

Integrantes

Tomás Cabrera · Juan Robaina · Gabriela Romero · Verónica Romero · Juan Corrales

Procedimiento técnico de respuesta a incidentes

Proyecto: Educación Vial IMSJ - Portal Vial. **Fecha:** 21/10/2026. **Entorno descrito:** instalación local con Docker Compose.

1. Objetivo

Organizar la detección, contención, análisis y recuperación de incidentes que afecten al portal, panel, API, base o adjuntos. El procedimiento utiliza la infraestructura y las herramientas presentes en el repositorio.

2. Coordinación y registro

Función del equipo	Referente
Coordinación del proyecto y backend	Tomás Cabrera.
Testing, documentación y registro de resultados	Juan Robaina.
Base de datos y comprobación de integridad	Gabriela Romero.
Interfaces públicas e internas	Verónica Romero y Juan Corrales.
Referente del cliente	Inspector de Tránsito.
Organismo administrador posterior	Intendencia de San José.
Contacto operativo institucional	Interlocución con el Inspector durante el proyecto; designación de función técnica al transferir.
Canal institucional de incidentes	Condición de transferencia: canal autorizado por la Intendencia; coordinación de proyecto con líder/co-líder.
Puesta en producción	La Intendencia definirá el canal y la función técnica responsable de incidentes.

En cada intervención se identifica a la persona que ejecutó la acción, la hora y el resultado. Las decisiones sobre aceptación o cambios del producto se registran en las reuniones del equipo y del referente.

3. Detección y clasificación

Situación	Señales	Primera comprobación
Indisponibilidad	Portal sin respuesta, error HTTP o contenedor unhealthy.	Estado de app/db y logs recientes.
Acceso irregular	Cuenta desconocida, cambios inesperados o sesión que pierde acceso.	Historial, estado de cuenta y validez del token.
Integridad	Registros o adjuntos ausentes, duplicados o inconsistentes.	Relaciones SQL, conteos y archivo asociado.
Publicación indebida	Contenido inesperado visible en el portal.	Estado, vigencia, autor y acciones de aprobación/publicación.
Carga sospechosa	Archivo inesperado o rechazo de tipo/tamaño.	Tipo real, ruta y operación que lo recibió.
Intentos repetidos	Respuestas 429 o reiteración de solicitudes inválidas.	IP del acceso, operación e intervalo de logs.

Para ordenar la intervención, atender primero a exposición de datos, acceso no autorizado y pérdida de integridad; después a indisponibilidad y fallos de alcance limitado. Un aviso automático se contrasta con su contexto y evidencia antes de determinar el impacto.

4. Preservación inicial

1. Registrar fecha, zona horaria, URL, pantalla u operación afectada y mensaje recibido.
2. Identificar la versión del código y el proyecto Compose que ejecuta la instalación.
3. Obtener estado de servicios y logs antes de reiniciar.
4. Conservar una copia protegida de esos registros y de los archivos involucrados.
5. Identificar si hay escrituras en curso y decidir la contención según el impacto.

Desde `backend`, estos comandos consultan el estado:

```text
docker compose ps -a
docker compose logs --timestamps --tail 200 app db
```

Los logs pueden contener datos operativos. La copia de trabajo debe tener acceso restringido. Las capturas para documentación conservan el mensaje y ocultan credenciales y datos personales.

5. Contención

Acceso de una cuenta

Si se conserva un acceso administrativo válido, revisar la cuenta involucrada. La operación **Quitar acceso** desactiva personal y revoca sus sesiones. El sistema impide quitar el propio acceso; la intervención debe preservar una cuenta administrativa legítima.

Un nuevo login reemplaza los tokens anteriores de la misma cuenta; logout revoca el token utilizado. Si se sospecha compromiso del servidor o de sus credenciales, tratar también la infraestructura y la configuración protegida.

Contenido público

Para una publicación incorrecta, registrar primero su identificador y estado. El personal puede utilizar **Retirar** para volver a borrador y revisar la información. La corrección recorre nuevamente la revisión, aprobación y publicación.

Compromiso o escritura insegura

Cuando sea necesario interrumpir las solicitudes para preservar datos, detener el servicio de aplicación del proyecto afectado:

```text
docker compose stop app
```

La base conserva su volumen. Mantener los registros y coordinar cualquier acceso SQL directo. La recuperación utiliza la configuración y los volúmenes identificados, conservando una copia del estado afectado para el análisis.

6. Análisis y corrección

1. Reconstruir la secuencia a partir de logs, historial y versión del código.
2. Precisar módulo, cuenta, datos y archivos afectados.
3. Contrastar el comportamiento con requisitos, permisos y contrato API.
4. Reproducir la causa en un entorno aislado con datos sintéticos.
5. Preparar la corrección y su comprobación específica.
6. Revisar el impacto sobre sesiones, esquema y archivos antes de aplicar la versión.

La auditoría administrativa conserva actor, acción, tipo, elemento y fecha. Para estudiar los valores anteriores se utilizan las copias y los registros disponibles; el historial actual no almacena una comparación completa de valores anteriores y posteriores.

7. Recuperación

El procedimiento de reconstrucción y restauración utiliza el respaldo del proyecto, la base de datos, los archivos cargados y la configuración protegida. La restauración se ensaya en un destino aislado antes de reemplazar una instalación de uso.

Comprobar antes de reabrir:

- Cuenta administrativa legítima y permisos por rol.
- Portal, API y servicios saludables.
- Consistencia de relaciones y conteos de datos.
- Descarga de adjuntos y estado de publicaciones.
- Consultas, franjas y reservas.
- Resultado de la prueba que reproduce el incidente y de los escenarios afectados.

Conservar el identificador del respaldo y las evidencias de la validación. La reapertura se registra con fecha, responsable y resultado.

8. Instrucciones para el registro de cada incidente

Esta ficha describe qué registrar ante una intervención; no documenta un incidente ocurrido.

Campo	Valor
Identificador	Asignar un código único con fecha y secuencia de intervención.
Detección y zona horaria	Registrar fecha y hora con zona America/Montevideo y el origen del aviso.
Versión y entorno	Registrar commit, proyecto Compose y equipo afectado.
Operación o componente	Identificar portal, panel, endpoint, base o adjunto involucrado.
Impacto y datos afectados	Describir alcance confirmado, cuentas, registros y disponibilidad.
Persona a cargo de la intervención	Identificar a quien ejecuta cada acción, bajo coordinación técnica.
Evidencia inicial	Conservar logs y capturas protegidos antes de modificar el estado.
Contención y hora	Registrar acciones de contención y hora efectiva de cada una.
Causa identificada	Relacionar causa comprobada con evidencia; separar hipótesis de resultados.
Corrección aplicada	Identificar cambio, configuración y versión que corrige la causa.
Respaldo y destino de recuperación	Registrar nombre, SHA-256, commit compatible y destino aislado.
Pruebas y resultados	Anotar casos ejecutados, resultados y archivos de evidencia.
Comunicación y decisión	Registrar interlocutor, decisión y autorización de reapertura cuando corresponda.
Reapertura y seguimiento	Registrar fecha, responsable, comprobaciones posteriores y cierre.

9. Referencias

Inventario de infraestructura, reconstrucción, manual de usuario, hallazgos y verificación.

INTENDENCIA DE SAN JOSÉ

PORTAL VIAL

Términos y condiciones

Integrantes

Tomás Cabrera · Juan Robaina · Gabriela Romero · Verónica Romero · Juan Corrales

Términos y condiciones del Sistema de Educación Vial IMSJ

Condiciones de acceso y uso aplicables en la República Oriental del Uruguay

Versión	Última actualización
1.1	22 de octubre de 2026

Estos términos regulan el acceso y el uso del Sistema de Educación Vial IMSJ, incluidos el portal informativo, las pruebas de práctica, la gestión de cuentas y el servicio de reservas. Al crear una cuenta o utilizar una función que exija aceptación, la persona usuaria declara haber leído estas condiciones y la Política de Privacidad.

Identificación y alcance del servicio

El Sistema es administrado en el marco institucional de la Intendencia de San José, a través de la Sección Tránsito. La denominación IMSJ identifica al portal y a sus funciones de educación vial y gestión de servicios.

El Sistema permite consultar noticias, materiales de educación vial, preguntas frecuentes y pruebas de práctica; también permite registrarse, autenticarse y reservar franjas disponibles. Las funciones administrativas están limitadas al personal autorizado.

Aceptación y registro

La aceptación se presenta mediante una acción afirmativa. El Sistema puede conservar la versión aceptada, la fecha, la hora y el identificador de la cuenta para acreditar dicha aceptación. La navegación por contenidos públicos no implica consentimiento para finalidades ajenas a la prestación del servicio.

Si la persona no acepta estas condiciones, puede consultar los contenidos públicos que no requieran cuenta, pero no puede utilizar las funciones para las que la aceptación sea necesaria.

Registro y seguridad de la cuenta

- La información proporcionada debe ser verdadera, exacta y mantenerse actualizada.
- La cédula, las credenciales y los tokens de acceso son personales y no deben compartirse.
- Cualquier uso no autorizado debe comunicarse mediante los canales institucionales publicados en el Sistema.
- Las cuentas del personal solo pueden utilizarse mientras exista autorización institucional vigente.
- Una cuenta puede bloquearse ante riesgo de fraude, acceso no autorizado o incumplimiento de estas condiciones.

Reservas y disponibilidad

Las reservas están sujetas a la disponibilidad y capacidad de cada franja. La confirmación electrónica acredita que el Sistema registró la solicitud, pero no amplía cupos ni modifica los requisitos administrativos aplicables.

Las cancelaciones se gestionan desde la cuenta de la persona usuaria. La disponibilidad se actualiza según las reservas vigentes y las reglas operativas del servicio.

Contenido educativo

Los materiales y las pruebas de práctica tienen finalidad educativa. Sus resultados no habilitan para conducir, no reemplazan los procedimientos oficiales ni garantizan la aprobación de evaluaciones teóricas o prácticas.

Uso permitido y conductas prohibidas

La persona usuaria debe utilizar el Sistema de forma lícita y respetuosa. Queda prohibido:

- Acceder o intentar acceder a cuentas, datos, funciones o áreas administrativas sin autorización.
- Interferir con la disponibilidad, automatizar solicitudes abusivas o eludir controles de seguridad.
- Cargar archivos maliciosos, manipular identificadores o utilizar el Sistema para fraude o suplantación.
- Redistribuir contenidos protegidos fuera de los usos autorizados por la ley o por sus titulares.
- Utilizar datos obtenidos del Sistema para finalidades incompatibles con aquellas informadas.

Propiedad intelectual

Los textos, imágenes, marcas, materiales y demás elementos pertenecen a sus respectivos titulares. El acceso concede un permiso personal, limitado y revocable para el uso informativo y educativo. Las licencias específicas indicadas en cada material prevalecen sobre esta regla general.

Enlaces y servicios de terceros

El Sistema puede incluir enlaces a sitios o contenidos de terceros. Cada tercero administra sus contenidos y sus tratamientos de datos. La persona usuaria debe revisar las condiciones y políticas correspondientes antes de utilizarlos.

Continuidad y cambios del servicio

La administración procurará mantener el Sistema disponible y seguro. Puede realizar mantenimiento, corregir errores o suspender temporalmente funciones cuando sea necesario para proteger la información o la continuidad del servicio.

Responsabilidad

Cada parte responde por los daños que le sean imputables conforme a la normativa aplicable. Estas condiciones no excluyen derechos inderogables ni limitan responsabilidades que la ley no permita limitar. La administración no responde por fallas atribuibles exclusivamente a la conexión, el dispositivo o la conducta de la persona usuaria, sin perjuicio de las medidas razonables de seguridad y continuidad que correspondan.

Protección de datos personales

El tratamiento de datos personales se rige por la Política de Privacidad del Sistema, la Ley N.º 18.331, sus modificativas y su normativa reglamentaria.

Modificación de estos términos

Estas condiciones pueden actualizarse para reflejar cambios legales, funcionales o de seguridad. La nueva versión indicará su fecha de vigencia. Los cambios sustanciales se comunicarán antes de su aplicación y, cuando corresponda, se solicitará una nueva aceptación.

Ley aplicable y solución de controversias

Estos términos se rigen por el derecho de la República Oriental del Uruguay. Las controversias se someten a las autoridades y tribunales competentes, sin restringir los mecanismos administrativos, de protección de datos o de defensa del consumidor que puedan corresponder.

Contacto

Las consultas sobre el uso del Sistema, las reservas o estas condiciones pueden presentarse mediante los canales institucionales publicados por la Intendencia de San José y los medios de contacto habilitados dentro del propio Sistema.

INTENDENCIA DE SAN JOSÉ

PORTAL VIAL

Política de privacidad

Integrantes

Tomás Cabrera · Juan Robaina · Gabriela Romero · Verónica Romero · Juan Corrales

Política de privacidad del Sistema de Educación Vial IMSJ

Información sobre el tratamiento de datos personales en Uruguay

Versión	Última actualización
1.1	22 de octubre de 2026

Esta política explica qué datos personales trata el Sistema de Educación Vial IMSJ, para qué los utiliza, con quién puede compartirlos, cómo los conserva y de qué manera pueden ejercer sus derechos las personas titulares. Se aplica al portal, las cuentas, las reservas, las funciones administrativas y los registros técnicos asociados.

Responsable del tratamiento

La administración del tratamiento corresponde a la Intendencia de San José, a través de la Sección Tránsito, en el marco de las funciones ofrecidas por el Sistema. Las solicitudes vinculadas con datos personales pueden presentarse mediante los canales institucionales publicados en el portal o por los medios oficiales de la Intendencia.

Datos personales tratados

Categoría	Datos comprendidos	Origen
Cuenta ciudadana	Cédula de identidad, identificador interno, contraseña almacenada mediante hash, rol y estado.	Persona titular y operación del Sistema.
Personal IMSJ	Nombre, cédula, rol, estado y datos de autenticación.	Institución y persona autorizada.
Reservas	Usuario, franja, fecha, hora, tipo de atención y fecha de creación.	Solicitud de la persona y agenda institucional.
Historial administrativo	Usuario actuante, acción, tipo e identificador del elemento, fecha y hora.	Uso de funciones administrativas.
Seguridad y acceso	Tokens, eventos de autenticación y registros técnicos como fecha, hora, IP o errores.	Generación automática durante el uso.
Comunicaciones	Datos incluidos por la persona en consultas o solicitudes.	Persona titular o representante.

El Sistema no solicita datos sensibles en sus formularios ordinarios. No deben incluirse datos de salud, origen racial o étnico, opiniones políticas, convicciones religiosas o morales, afiliación sindical o vida sexual en campos libres.

Finalidades y bases jurídicas

Finalidad	Datos principales	Base jurídica
Crear y administrar cuentas	Cédula, contraseña, rol y estado.	Prestación del servicio, función pública y consentimiento cuando corresponda.
Autenticar y proteger el acceso	Credenciales, token y registros de seguridad.	Seguridad del servicio, cumplimiento legal y responsabilidad proactiva.
Gestionar reservas	Cuenta, franja, fecha, hora y tipo.	Solicitud de la persona y gestión del servicio público.
Administrar contenidos y personal	Nombre, cédula, rol e historial de acciones.	Relación funcional, control interno y seguridad.
Prevenir y responder incidentes	Registros técnicos y de auditoría.	Obligaciones de seguridad y protección de datos.
Atender derechos y reclamos	Identidad, solicitud y antecedentes necesarios.	Cumplimiento de obligaciones legales.

Información obligatoria y consecuencias

Los campos obligatorios son necesarios para crear una cuenta, autenticarla o registrar una reserva. La negativa a proporcionar la cédula o los datos de la reserva impide utilizar esas funciones, pero no limita el acceso a contenidos públicos que no los requieran.

Destinatarios y encargados

Pueden acceder a los datos únicamente el personal autorizado de la Intendencia de San José, los proveedores que operen infraestructura o soporte por cuenta de la institución y las autoridades que los requieran conforme a una norma u orden válida. Los encargados deben mantener confidencialidad, seguridad y uso limitado a la finalidad encomendada.

Los datos personales no se venden ni se utilizan para publicidad ajena al servicio. Cualquier comunicación para una finalidad diferente requiere una base jurídica independiente y la información previa correspondiente.

Transferencias internacionales

Los datos se mantienen en la infraestructura asignada al Sistema. Si un servicio de alojamiento, respaldo, correo o soporte implicara una transferencia al exterior, se verificará el nivel de protección del destino y se aplicarán las autorizaciones o garantías exigidas por la normativa uruguaya.

Criterios de conservación

Información	Criterio de conservación
Cuenta y perfil	Mientras la cuenta permanezca activa y durante el período necesario para atender derechos y obligaciones legales.
Reservas	Durante el tiempo necesario para gestionar la agenda, respaldar la atención y resolver reclamos.
Historial administrativo	Durante el período necesario para trazabilidad, control interno y seguridad.
Token de acceso	Hasta ocho horas, cierre de sesión o revocación, según ocurra primero.
Registros técnicos	Durante un período proporcional a las necesidades de detección de incidentes y diagnóstico.
Solicitudes de derechos	Durante el tiempo necesario para documentar la respuesta y acreditar el cumplimiento.

Una vez cumplida la finalidad, los datos se eliminan, anonimizan o bloquean cuando una obligación legal exija conservarlos únicamente para atender responsabilidades.

Medidas de seguridad

El Sistema aplica medidas técnicas y organizativas proporcionales al riesgo para proteger la confidencialidad, integridad y disponibilidad de la información. Entre ellas se incluyen:

- Contraseñas almacenadas mediante hash y control de intentos de acceso.
- Separación de funciones por rol, tokens con vencimiento y revocación de sesiones.
- Validación de entradas, consultas preparadas y registro de acciones administrativas.
- Cifrado en tránsito mediante HTTPS y gestión de secretos fuera del código fuente.
- Acceso de mínimo privilegio, copias de seguridad y procedimientos de respuesta a incidentes.

Derechos de las personas titulares

La persona titular puede solicitar información sobre el tratamiento, acceder a sus datos y, cuando corresponda, pedir su rectificación, actualización, inclusión o supresión. También puede oponerse o impugnar valoraciones automatizadas en los casos previstos por la normativa.

La solicitud se presenta mediante los canales institucionales publicados en el Sistema e incluye la información necesaria para acreditar identidad y localizar los datos. El acceso se brinda gratuitamente en los intervalos legales y la respuesta se proporciona dentro del plazo máximo de cinco días hábiles.

Revocación del consentimiento

Cuando el tratamiento se base en consentimiento, este puede revocarse por el mismo canal utilizado para ejercer derechos. La revocación no afecta la licitud del tratamiento anterior ni impide conservar información cuando exista otra obligación legal que lo justifique.

Datos de menores de edad

Cuando una persona menor de edad utilice una función que requiera cuenta, el tratamiento se limita a los datos necesarios para prestar el servicio. La información debe presentarse en lenguaje comprensible y debe verificarse la intervención de representantes cuando corresponda.

Vulneraciones de seguridad

Ante un incidente que afecte datos personales se activan los procedimientos de contención, análisis y mitigación. Cuando la vulneración incida en la protección de los datos, se comunica a la URCDP dentro del plazo máximo de 72 horas desde que sea conocida y se informa a las personas afectadas cuando exista un riesgo significativo para sus derechos.

Cambios a esta política

La política puede actualizarse por cambios legales, técnicos o funcionales. La versión vigente indica su fecha. Los cambios que alteren finalidades, destinatarios o bases jurídicas se informan antes de aplicarse y, si corresponde, requieren un nuevo consentimiento.

Reclamos ante la autoridad

Si una persona considera que sus derechos no fueron atendidos, puede presentar una consulta o denuncia ante la Unidad Reguladora y de Control de Datos Personales. La información y los trámites están disponibles en gub.uy/urcdp.

INTENDENCIA DE SAN JOSÉ

PORTAL VIAL

Reflexión ética

Integrantes

Tomás Cabrera · Juan Robaina · Gabriela Romero · Verónica Romero · Juan Corrales

Reflexión ética

Las pruebas de seguridad se realizaron únicamente sobre el entorno local autorizado del proyecto IMSJ y con datos de prueba. No se atacaron sistemas externos ni se intentó acceder a información ajena.

Los resultados de herramientas como Semgrep, OWASP ZAP y Nmap se analizaron dentro del contexto del sistema. Una alerta automática no demuestra por sí sola una vulnerabilidad, y la ausencia de alertas tampoco garantiza seguridad absoluta.

Las evidencias deben conservar la fecha, el alcance y el resultado de cada prueba, sin publicar contraseñas, tokens ni datos personales. Los hallazgos se comunican al equipo para corregirlos y volver a comprobar el comportamiento afectado.

El objetivo de estas actividades fue reducir riesgos y mejorar el proyecto, respetando la privacidad de las personas y los límites acordados para la evaluación.